CardKeep 0.6.0 mobile audit

Version 0.6.0

Commit cdcf49d

2026-10-21

Revision 1.0

CardKeep 0.6.0 mobile release audit

`MOBILE APPLICATION RELEASE AUDIT ================================ Application: CardKeep (com.axialforge.cardkeep) Version/Build: 0.6.0 (versionCode 2010, arm64) Commit: cdcf49d Tag: v0.6.0 Platform(s): Android (iOS out of scope: scaffolding only) Environment: production (GitHub Releases) Artifact: CardKeep-0.6.0-arm64-v8a.apk sha256 CC9B63BC...F52501 (+ armeabi-v7a, x86_64) Evidence mode: artifact + runtime (Android 16 emulator; owner's phone not connected) Identity gate: PASS (audited APKs are the v0.6.0 release assets; same signing key as earlier releases) Audited on: 2026-10-21 Store policies checked: 2026-10-21 (Google Play Console Help + Developer Policy Center, see Appendix C)`

DECISION: NO-GO

Two reachable data-loss defects and two privacy defects are open. A crash during restore can wipe the whole contact library (proven by a test), batch-scanned cards can be lost if the app is killed, deleted contacts are never really deleted, and the app ships Google's ML Kit telemetry library while saying it only goes online for updates. For Google Play specifically, four more store blockers apply (self-updater, unused media/microphone permissions, no AAB, no privacy policy). All are fixable; none needs a redesign.

Coverage: 194/231 controls tested (PASS 98 + PASS-WARN 55 + FAIL 41), 21 N/A, 8 NOT TESTED, 5 BLOCKED, 3 MANUAL REVIEW.

Scores (value / coverage of that area)

Area	Score	Coverage	Basis
Security (local, platform, network, input)	87/100	87% (61/69 tested)	12 open: 2 S2, 7 S1, 3 S0
Privacy (privacy, permissions, logging)	82/100	89% (34/38)	4 open: 2 S3, 2 S1
Reliability & data integrity	61/100	91% (32/35)	9 open: 1 S4, 1 S3, 2 S2, 5 S1
UX, accessibility, performance	94/100	88% (21/24)	5 open: 1 S2, 3 S1, 1 S0
Store (Google Play)	75/100	69% (20/29)	7 open: 2 S3, 2 S2, 3 S1
Build & supply chain	97/100	71% (29/41)	4 open: 3 S1, 1 S0

Scores do not override the decision: one S4 data-loss finding alone makes this NO-GO.

Counts (open): Blockers 9 · S4 1 · S3 5 · S2 7 · S1 23 · S0 5 · plus 2 duplicates merged.

Release blockers

ID	Sev
MOB-REL-0001	S4
MOB-REL-0002	S3
MOB-PRV-0001	S3
MOB-PRV-0002	S3
MOB-STORE-0001	S3
MOB-STORE-0002	S3
MOB-STORE-0003	S2
MOB-STORE-0004	S2
MOB-STORE-0005	S1

For the **current GitHub channel** only the first four rows block a release; the STORE rows block a Play upload.

High and moderate findings (not blockers)

ID	Sev
MOB-SEC-0001	S2
MOB-SEC-0100	S2
MOB-REL-0003	S2
MOB-REL-0004	S2
MOB-UX-0001	S2

The 23 S1 and 5 S0 items are in Appendix A (findings index) and their files.

What is missing for a GO

1. Fix REL-0001 (journalled, resumable swap; never delete the only copy) and REL-0002 (persist queued captures before reading), with crash-simulation tests.
2. Decide on ML Kit telemetry (MOB-PRV-0001): capture traffic on a device; then disable it if possible or disclose it in the README, app and Data safety.
3. Purge on delete (MOB-PRV-0002): remove rows and image files after an undo window; exclude tombstones from backups.
4. Declare backup rules (MOB-SEC-0001) and say in the app what is and isn't backed up.
5. For Play: a Play flavour without the updater, remove plugin permissions with `tools:node="remove"`, AAB + Play App Signing in CI, a published privacy policy, Data safety answers.
6. Runtime gaps: phone test of NFC and the real camera, the lock-screen notification text, `bmgr` backup contents, a profile-build frame-timing run, and an OSV/GHSA lookup for bundled SQLite and OpenCV.

Manual review queue

Item	How to check
ML Kit telemetry traffic	Run the release build on a phone behind a proxy (e.g. PCAPdroid) while scanning; look for `firebaselogging-pa.googleapis.com` / `play.googleapis.com/log`

Item	How to check
Media / microphone prompts	Use every feature on Android 13+; confirm no media or microphone permission dialog ever appears
Lock-screen reminder text	Set a reminder 2 minutes ahead, lock the phone, read what shows
What Android backs up	`adb shell bmgr backupnow com.axialforge.cardkeep` with a backup transport, then list the backup
Keystore backup	Confirm a second copy of `keys/` exists off this PC (losing it means no more updates)
Known vulnerabilities	Query OSV for sqlite3 3.50.x and OpenCV 4.x versions bundled by sqlite3/opencv_dart
Play content rating, target audience, signing strategy	Owner decisions at Play Console setup

Method

Seven domain audits ran in parallel against the same artifact lineage (identity in Appendix A), each writing structured findings (`audit/findings/`) and a coverage table; the consolidation merged duplicates (MOB-AND-0001 into MOB-SEC-0001, MOB-BLD-0001 into MOB-STORE-0002) and re-ran the one data-loss proof that an auditor could not finish. No app code was changed during the audit. Runtime checks used the shipped x86_64 APK on the emulator; phone-only behaviour (NFC, the real camera, battery saver) is BLOCKED here and listed in the phone test sheets.

Appendices: A scope, identity and attack surface · B inventories (permissions, data, Data safety draft) and SBOM · C store checklist and policies · D runtime evidence and screenshots · Findings index · Coverage & Evidence Matrix · all findings.

MOB-A11Y-0001 - Round header buttons (DiscButton) are 46x46 dp, below the 48 dp touch-target minimum

Severity S1 | **Status** open | **Confidence** high | **Basis** runtime | **Blockers** []

Description. `DiscButton` draws its tap area as a fixed 46x46 dp box. The UI dump of the shipped x86_64 release build reports these controls at 46x46 dp, while Android accessibility guidance and the Accessibility Scanner flag targets under 48x48 dp. Other app buttons (IconButton, chips, list rows) measure 48 dp or more, so only this shared widget is short. The labels are present (`semanticLabel: tooltip`), so TalkBack is fine; only target size is affected. S1: 2 dp short, buttons are well separated.

Steps to reproduce. 1. Open Contacts. 2. `adb shell uiautomator dump`; read the bounds of `content-desc="Menu"` and `"Add contact"`.

Expected. At least 48x48 dp. **Observed.** 138x138 px at density 480 (3.0) = 46x46 dp; same for detail Back/Edit, Review queue "Scan cards", Duplicates "Check the whole library again".

Evidence. - UI dump (Contacts): `View desc=Menu w=46 h=46`, `View desc=Add contact w=46 h=46` - UI dump (detail): `View desc=Back w=46 h=46`, `View desc=Edit w=46 h=46` - Screenshots: `audit/artifact/screens/01_launch_empty.png`, `audit/artifact/screens/09_detail_long.png`

Impact. User: slightly harder to hit for users with motor impairments; will be flagged by Accessibility Scanner / Play pre-launch report. **Recommended remediation.** Make the SizedBox 48x48 (or wrap in `ConstrainedBox(minWidth/minHeight: 48)`) keeping the 46 dp visual disc. **Verification procedure.** Re-dump the four screens; every DiscButton reports >= 48x48 dp.

References. WCAG 2.2 SC 2.5.8 Target Size (Minimum); Android accessibility "touch target size 48dp"; MASVS n/a.

MOB-A11Y-0002 - Scan mode selector (One card / Batch / Pile) has 34 dp tall touch targets

Severity S1 | **Status** open | **Confidence** high | **Basis** runtime | **Blockers** []

Description. On the Scan screen the three mode buttons report 80x34, 59x34 and 46x34 dp in the UI dump. Height is well under 48 dp, and "Pile mode" is also under 48 dp wide. The scanner is used one-handed at events, which makes small targets more costly.

Steps to reproduce. 1. Contacts > Scan card, allow camera. 2. `adb shell uiautomator dump`; read the bounds of "One card mode", "Batch mode", "Pile mode".

Expected. Each target at least 48x48 dp (visual pill can stay smaller, with padding to the tap area). **Observed.** `Button One card mode w=80 h=34`, `Button Batch mode w=59 h=34`, `Button Pile mode w=46 h=34`.

Evidence. UI dump above; screenshot `audit/artifact/screens/13_scan.png`.

Impact. User: mis-taps between modes; Accessibility Scanner flag. **Recommended remediation.** Give the mode buttons `minimumSize: Size(48, 48)` / `tapTargetSize: MaterialTapTargetSize.padded`. **Verification procedure.** Re-dump the Scan screen; all three report >= 48 dp in both dimensions.

References. WCAG 2.2 SC 2.5.8; Android touch target guidance (48 dp).

MOB-AND-0001 - "Android auto-backup is on by default, so the contacts database and card photos go to Google cloud and device-transfer backups"

Severity S2 | **Status** duplicate (tracked as MOB-SEC-0001) | **Confidence** high | **Basis** artifact | **Blockers** [privacy]

Consolidation: same defect as MOB-SEC-0001; counted there, not here.

Android auto-backup is on by default, so the contacts database and card photos go to Google cloud and device-transfer backups

Description

The merged release manifest does not set android:allowBackup, android:fullBackupContent or android:dataExtractionRules, so the Android default (allowBackup=true) applies. Auto Backup and device-to-device transfer then include app_flutter/card_organizer.sqlite and app_flutter/cards/. The app's own backup design (user-chosen .zip via SAF) implies on-device-only intent, and the threat model lists 'backups reading it' as a main risk. After uninstall and reinstall on a phone signed into the same Google account, data may silently come back; this is not documented. Google cloud backups are end-to-end encrypted with the lock-screen credential on Android 9+, which limits but does not remove the exposure.

Expected behaviour

Backup behaviour is a deliberate, documented choice: allowBackup=false plus dataExtractionRules excluding the database (Android 12+), or an explicit include list stated in the privacy notes.

Observed behaviour

Default full Auto Backup of contact PII; reinstall behaviour undocumented.

Recommended remediation

Add android:allowBackup="false" and a data_extraction_rules.xml that excludes cloud-backup and device-transfer of the database and cards/ (or document the intent if keeping it). Reflect it in the privacy text / Data Safety.

Verification procedure

Rebuild; manifest-xmltree shows allowBackup=false and dataExtractionRules; `adb shell bmgr backupnow com.axialforge.cardkeep` reports the package not eligible.

MOB-API-0001 - "Update download falls back to a size-only check when GitHub lists no SHA-256 digest, and has no maximum size"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-BLD-0001 - "Shipped APK declares RECORD_AUDIO, READ_MEDIA_VIDEO and READ_MEDIA_AUDIO that the app never uses"

Severity S2 | **Status** duplicate (tracked as MOB-STORE-0002) | **Confidence** medium | **Basis** artifact | **Blockers** [store]

Consolidation: same defect as MOB-STORE-0002; counted there, not here.

Shipped APK declares RECORD_AUDIO, READ_MEDIA_VIDEO and READ_MEDIA_AUDIO that the app never uses

Description

The release manifest merges in RECORD_AUDIO (no maxSdkVersion), READ_MEDIA_VIDEO and READ_MEDIA_AUDIO from plugins. CardKeep only takes still card photos and imports .vcf/.csv/.zip through SAF. Unused permissions widen the surface, show on the app's permission page, and READ_MEDIA_* fall under Google Play's Photo and Video Permissions policy when the app moves to Play (M9). Presence is certain; the exact contributing plugin is medium confidence.

Expected behaviour

Only permissions the app uses ship.

Observed behaviour

Three unused dangerous permissions ship.

Recommended remediation

Add uses-permission entries with tools:node="remove" for RECORD_AUDIO, READ_MEDIA_VIDEO, READ_MEDIA_AUDIO (and READ_MEDIA_IMAGES if only the system photo picker is used); construct CameraController with enableAudio: false; re-test capture and gallery import.

Verification procedure

aapt2 dump permissions on the new APK lists none of the removed permissions; capture and gallery import still work on the emulator.

MOB-BLD-0002 - "Release build silently falls back to the debug signing key when key.properties is missing"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

Release build silently falls back to the debug signing key when key.properties is missing

Description

If key.properties is absent (a CI secret unset or renamed), `flutter build apk --release` still succeeds and signs with the debug key, and release.yml would publish it. Installed users could not update to it (signature mismatch fails safe), but a debug-signed public release breaks the update chain. No CI step verifies the signer certificate before upload.

Expected behaviour

A tag build fails if the release key is unavailable, and CI checks the signer SHA-256 against the known release certificate.

Observed behaviour

Silent fallback; no certificate check.

Recommended remediation

Fail the build in CI when key.properties is missing (e.g. if System.getenv('CI') != null), and add `apksigner verify --print-certs` compared to the known cert SHA-256 (4ffa7fe0...3a2820) before publishing.

Verification procedure

Run the release workflow on a throwaway tag with the keystore secret removed: it must fail.

MOB-BLD-0003 - "CI actions are pinned to moving major tags, and releases carry no provenance, checksums file or SBOM"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

CI actions are pinned to moving major tags, and releases carry no provenance, checksums file or SBOM

Description

The release job holds the signing keystore secrets and contents:write, yet third-party actions are referenced by mutable tags. A compromised tag of subosito/flutter-action or softprops/action-gh-release would run with access to the keystore. No build attestation, SHA256SUMS or SBOM is attached to the GitHub Release, and the NDK is fetched via sdkmanager without a checksum pin. Mitigation present: tag-vs-pubspec version check, flutter test before build, Flutter version pinned to 3.47.0.

Expected behaviour

Third-party actions pinned to full commit SHAs; provenance attestation and checksums published.

Observed behaviour

Tag-pinned actions, no attestation or checksums.

Recommended remediation

Pin each action to a commit SHA (Dependabot can bump them), add actions/attest-build-provenance and a SHA256SUMS asset, optionally generate a CycloneDX SBOM in CI.

Verification procedure

grep 'uses:' in workflows shows 40-hex SHAs; next release page shows attestation and SHA256SUMS.

MOB-BLD-0004 - "R8 mapping and Dart symbol files are not archived, so release crashes cannot be symbolicated"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

R8 mapping and Dart symbol files are not archived, so release crashes cannot be symbolicated

Description

R8 runs on release (proguard-rules.pro is applied, and CLAUDE.md records a 0.2.x R8 stripping bug found only in release), but mapping.txt is discarded with the runner and Dart code is not built with --split-debug-info, so no symbol files exist for the shipped binaries. No user risk; it limits diagnosing field crashes.

Expected behaviour

mapping.txt (and symbols if adopted) retained per release.

Observed behaviour

Not retained.

Recommended remediation

Upload build/app/outputs/mapping/release/mapping.txt with actions/upload-artifact (long retention) or as a release asset.

Verification procedure

Next tag's workflow run lists a mapping artifact.

MOB-BLD-0005 - "APK is signed with scheme v2 only; v3 (key rotation) is not enabled and there is no recorded key backup"

Severity S0 | **Status** open | **Confidence** high | **Basis** artifact | **Blockers** []

APK is signed with scheme v2 only; v3 (key rotation) is not enabled and there is no recorded key backup

Description

apksigner shows v2 only. v2 is sufficient for minSdk 24, but without v3 the key can never be rotated in place for sideloaded users, so loss or compromise of the single key ends the update chain. Where the offline backup of keys/ lives is not recorded in the repo docs.

Expected behaviour

v2+v3 signatures and a documented key backup.

Observed behaviour

v2 only.

Recommended remediation

Set enableV3Signing = true in the release signing config; record the keystore backup location in CLAUDE.md.

Verification procedure

apksigner verify reports v3 true.

MOB-PERF-0001 - About 80 MB of memory stays allocated after leaving the Scan screen

Severity S0 | **Status** open | **Confidence** medium | **Basis** runtime | **Blockers** []

Description. Total PSS rose from 86.9 MB (idle on Contacts) to 182.7 MB with the Scan screen open (native heap 25.8 MB -> 99.2 MB). After closing Scan and visiting eleven other screens, PSS stayed at 165-167 MB. It is likely the ML Kit text/barcode recognizers and OpenCV buffers held by long-lived providers rather than a growing leak (it did not grow further), so S0. On low-RAM devices (minSdk 24 phones with 2-3 GB) this raises the chance the app is killed in the background.

Evidence. `idle (Contacts) TOTAL PSS: 86891 KB Native Heap 25836 KB Scan open TOTAL PSS: 182749 KB Native Heap 99196 KB 5 s after closing Scan TOTAL PSS: 167490 KB after 11 more screens TOTAL PSS: 165847 KB (adb shell dumpsys meminfo com.axialforge.cardkeep)`. Screenshot `audit/artifact/screens/13_scan.png`.

Impact. User: slightly higher background-kill risk on low-memory phones. **Recommended remediation.** Close recognizers / release OpenCV mats when the Scan route is disposed (autoDispose providers), and re-check with repeated open/close cycles. **Verification procedure.** Open/close Scan 5 times; PSS returns to within ~20 MB of idle and does not climb.

References. Android "Manage your app's memory", checked 2026-10-21.

MOB-PRV-0001 - "ML Kit ships Google's datatransport telemetry stack, contradicting the 'only goes online for updates / no analytics' claims"

Severity S3 | **Status** open | **Confidence** medium | **Basis** artifact | **Blockers** [privacy, store]

Evidence and reasoning in front matter. Related: MOB-STORE-0005 (Data Safety answers not prepared).

MOB-PRV-0002 - "Deleting a contact never removes its data: tombstone only, card photos, logos and contact details kept forever and copied into every backup"

Severity S3 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [privacy]

See front matter.

MOB-PRV-0003 - "before_restore/ fallback copy of the whole library is kept indefinitely with no way to discard it"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

See front matter.

MOB-PRV-0004 - "open_filex and camera_android_camerax also merge legacy READ/WRITE_EXTERNAL_STORAGE that the app never uses"

Severity S1 | **Status** open | **Confidence** high | **Basis** artifact | **Blockers** []

See front matter.

MOB-REL-0001 - Restore swap is not crash-safe; a re-run after a partial swap deletes the user's pre-restore data and opens an empty database

Severity S4 | **Status** open | **Confidence** high | **Basis** runtime | **Blockers** [data-loss]

Description. `applyPendingRestore` decides whether to run only by checking that `restore_pending/.ready` exists. That marker is removed last of all (`:185`, `staged.delete`). The steps before it are not idempotent:

1. It deletes `before_restore/` (`:173`).
2. It moves the live DB, WAL and SHM into `before_restore/` (`:175-178`).
3. It moves `cards/` into `before_restore/` (`:180`).
4. It moves the staged DB into place (`:182`).
5. It moves the staged `cards/` into place (`:184`).
6. It deletes `restore_pending/` (`:185`).

If the process dies after step 2 and before step 6 (the OS kills a slow start, the battery dies, or the user force-stops a start that looks frozen while a large `cards/` tree is being renamed), `.ready` is still there on the next start. The re-run then does the following:

- **Killed after step 2, 3 or 4:** step 1 deletes `before_restore/`, which by now holds the user's **only copy of the original database and card images**. If the staged DB was still in `restore_pending`, the restore then completes, but the safety copy is gone for good.
- **Killed after step 4 or 5:** step 1 deletes the original data, and step 2 moves the *restored* DB into `before_restore/`. Step 4 then throws `FileSystemException`, because the staged DB has already been moved. `main()` swallows the error (`debugPrint`, `main.dart:17`). drift finds no `card_organizer.sqlite` and creates an **empty database**. The user sees an empty app. The original data is gone. The restored data sits in a hidden folder that nothing in the UI can reach (MOB-REL-0003). `.ready` is still present, so every later start repeats the failure and **deletes `before_restore/` again**, which destroys the restored data too, while the new empty database is moved aside each time.

The rename steps themselves are fast. What makes the crash window realistic is the directory renames, which run while the app shows no UI before `runApp`, and the fact that a single interruption costs everything with no warning. The consequence is total loss of the contact database, so the severity is S4.

Preconditions. The user restored a backup and the app restarts. The process dies partway through `applyPendingRestore`.

Steps to reproduce (deterministic simulation). 1. In a temp docs folder, create `card_organizer.sqlite` ("RESTORED"), `before_restore/card_organizer.sqlite` ("ORIGINAL") and `restore_pending/.ready`, with no staged DB. This is the state after a kill following step 4. 2. Call `applyPendingRestore(docs)`. 3. Trace of the code: `before_restore/` with ORIGINAL is deleted at `:173`. RESTORED is moved into `before_restore/` at `:177`. `File(restore_pending/card_organizer.sqlite).rename` throws at `:182`. `docs` has no database, and `.ready` is still present.

Confirmed by a run (consolidation, 2026-10-21). A unit test set up the state after a kill following step 4 (live DB = restored copy, `before_restore/` = original, `restore_pending/.ready` present, staged DB already moved) and called `applyPendingRestore(docs)`. Output:

```
error: PathNotFoundException live db exists: false before_restore holds: RESTORED .ready still there: true
```

The original database was deleted, the live database is gone (drift will create an empty one), and the marker remains, so the next start repeats the loss. The test file was removed after the run.

Expected. The swap is resumable or transactional. `before_restore` is never deleted while it holds the only copy of user data. A failed swap is rolled back and reported.

Root cause. A single completion marker is checked at the start and removed at the end. The delete-first handling of the fallback folder is not idempotent.

Remediation. - Write a journal file (`restore_state`: `moving_old`, `moving_new`, `done`) and resume from the recorded phase. - Delete the old `before_restore` only after the new swap has finished and the database opens. - Rename `restore_pending/.ready` to `.applying` before step 1, and if `.applying` is found at start, roll back from `before_restore`. - Surface failures to the user instead of swallowing them in `main()`.

Verification. Unit tests that simulate a kill after each step (set up each intermediate state and call `applyPendingRestore` again) and assert that either the original or the restored database ends up in `docs/` and no copy is lost.

References. CWE-367 (TOCTOU-style non-atomic multi-step operation), MASVS-RESILIENCE (data integrity).

MOB-REL-0002 - Queued scan captures exist only in memory; killing the app during batch scanning loses them

Severity S3 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [data-loss]

Description. The scanner accepts up to 8 captures ahead of the reader (`ScanWorker.maxQueued`). `scan_screen.dart:240` and `:307` call `worker.add(ScanJob(bytes))` with no `pending` file. The crash-safe copy is only written by `ScanPipeline.process` (`scan_pipeline.dart:122`) once the job reaches the head of the queue. On top of that, `ImageStore.commit` deletes the pending copy (`image_store.dart:55`) *before* OCR, QR, logo extraction and `queue.enqueue` run (`scan_pipeline.dart:132-134`, `scan_worker.dart:65`). ML Kit OCR takes seconds per card.

The stated contract ("never lose a capture", `image_store.dart:30-31`, `app.dart:44-45`) therefore fails in two windows: 1. Every capture still waiting in `_jobs` (up to 7) has no file on disk. 2. The capture being read has already lost its pending file and has no `cards` row yet. Its images are left orphaned in `cards/`, and nothing references them.

Severity is S3 rather than S4 because the paper card can usually be scanned again. At an event, though, the loss is silent and the card may already have been handed back.

Preconditions. Several captures queued ("Reading N" above 1), or a capture being read.

Steps to reproduce. 1. Batch-scan or gallery-import 5 or more cards quickly. 2. While "Reading N" shows, swipe the app away from Recents (or let the OS kill it). 3. Reopen the app. Start-up recovery reads at most the one file still in `pending/`. The other captures are gone, and no message says so.

Expected. Every accepted capture is on disk before it is acknowledged. The pending copy is deleted only after the `cards` row is committed.

Observed (code). Recovery (`scan_worker.dart:44-50`) can only find files in `pending/`, and queued jobs never reach `pending/` before they are processed.

Root cause. `savePending` runs in the pipeline instead of at capture time. The pending copy is removed during the image commit instead of after the enqueue.

Remediation. Call `store.savePending` in `ScanWorker.add` (or in scan_screen before `add`) and pass it as `pending`. Delete the pending copy only after `queue.enqueue` succeeds.

Verification. Test 1: queue 3 jobs behind a blocking fake pipeline and assert that 3 files exist in `pending/`. Test 2: throw after `commit` and before `enqueue`, and assert that the pending file still exists.

MOB-REL-0003 - A failed or bad restore is silent, and the before_restore safety copy cannot be reached from the app

Severity S2 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

Description. `applyPendingRestore` keeps the old database and images in `before_restore/`, but nothing else in `lib/` refers to that folder (`grep -rn before_restore lib` finds only backup.dart). There is no undo for a restore.

If the swap throws, `main()` only logs it with `debugPrint('Restore failed: $e')`. The app then opens whatever is in place, which can be a new, empty database (see MOB-REL-0001), and the user is never told.

A staged database can pass the hash check and still fail to open, for example a backup taken from an already-damaged database. In that case drift fails at open, and nothing rolls back to the old copy automatically.

Each new restore deletes the previous `before_restore` without asking (`backup.dart:173`), so there is only one level of fallback. One level is acceptable. Having no way to reach it is the defect.

Expected. - A failed swap rolls back from `before_restore` and tells the user. - After a restore, an "Undo restore" option stays available until the next restore.

Remediation. - Wrap the swap in rollback logic, record the outcome in a marker file, and show it in a snackbar on the next start. - Open the new database once and run `PRAGMA integrity_check` before discarding the old copy. - Add an "Undo last restore" action that stages `before_restore`.

Verification. Test: stage a backup whose database bytes are not SQLite but whose hashes are valid. After apply and open, the old database is back in place and the failure is reported.

MOB-REL-0004 - An offline or interrupted update download throws an uncaught error and leaves the sheet on its progress bar

Severity S2 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

Description. `Updater.check` turns every network error into an `UpdateException` (`updater.dart:103-111`), so the update check fails gracefully offline. That part passes domain 20.

`Updater.download` does not do the same. Neither `client.send(req).timeout(20s)` (`:167`) nor the `await for` loop over `resp.stream` (`:172`) is wrapped. A network loss raises a `SocketException`, `ClientException`, `TimeoutException` or `HttpException`. `_install` catches only `on UpdateException` (`update_sheet.dart:50`), so: - `_progress` stays set and the progress bar stays on screen; - no error message appears; - the exception surfaces as unhandled.

A connection that stalls without closing never ends, because the stream has no idle timeout. The partial APK stays in the temp folder until the next attempt deletes it (`:165`).

Steps to reproduce. 1. Open the update sheet while online, with an update available. 2. Turn on airplane mode. 3. Tap Install.

Expected. "The download did not work. Check your connection." with a way to retry.

Remediation. - Wrap the send and the stream loop in try/catch and rethrow as `UpdateException`. - Add an idle timeout to the stream (`resp.stream.timeout(...)`). - In the sheet, also catch generic errors and reset `_progress`.

Verification. Unit test with a MockClient that throws mid-stream, asserting an `UpdateException`. Runtime check: airplane mode during a download on the emulator.

MOB-REL-0005 - A capture that always fails to process is retried on every launch, with a recurring "Reading 1 card left from last time"

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

Description. Sometimes `pipeline.process` throws before `commit`, for example on an undecodable JPEG or an opencv error in the isolate. The worker swallows the error (`catch (_) {}` at `scan_worker.dart:71`) and leaves the pending file "for the next recovery".

There is no retry count, no quarantine and no message to the user. Every launch reads the file again, fails again, and shows the snackbar again. The user cannot see the file or remove it.

Remediation. Count attempts, either in the file name or in a sidecar file. After 2 failures, move the capture to the queue as a "could not read" item the user can discard, or move it to `pending/failed/`.

Verification. Test with a pipeline that always throws for one file: after two `recover()` calls, that file is no longer re-queued.

MOB-REL-0006 - Several multi-step writes are not in a transaction (job change, import, event delete, card link)

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

Description. Merge, undo, retire, moveFollowup, contact save/delete/restore and the tag operations all use `db.transaction` (12 call sites). The methods below do not:

- `changeJob` marks the old role *former* (`:281`), inserts the new role, and then updates emails and roles. An error after the first write leaves the person with no current role.
- `importContacts` saves each contact, then merges or tombstones it in separate steps. A kill partway through leaves the file half imported, and "skipped" duplicates leave tombstoned rows behind.
- `EventsRepository.delete` ends the event's sessions and tombstones the event in two separate statements.
- `CardQueueRepository.link` runs up to three updates: the logo, the met-at event, and the card status. If it fails after the person is updated, the card stays in the queue, and a retried `autoSave` creates a duplicate contact.

These statements are quick, so being killed between them is unlikely. Errors are the more realistic trigger.

Remediation. Wrap each of these method bodies in `db.transaction`. For import, use one transaction per contact.

Verification. Fault-injection tests that make a later step throw, then assert that no partial rows remain.

MOB-REL-0007 - Reminder sync calls cancelAll, which also clears today's reminder already shown; ids come from String.hashCode

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

Description. `sync` calls `_plugin.cancelAll()` and then re-schedules only follow-ups dated in the future. On Android, `cancelAll` also removes notifications that are already showing. A reminder that fired at 08:00 today therefore vanishes the next time `sync` runs, which is on app start or any follow-up edit, before the user has acted on it.

Ids are `personId.hashCode & 0x3fffffff`. The Dart VM computes string hash codes deterministically, so the ids are stable. Two people can still collide, in which case one reminder replaces the other. The chance is about n^2/2^31, roughly 0.05% with 1,000 open follow-ups. That is low, but nothing guards against it.

Remediation. - Diff against `pendingNotificationRequests()` and cancel only ids that are no longer wanted. - Assign ids from a stored counter instead of from hashCode.

Verification. Fake-plugin test: re-syncing an unchanged list cancels nothing.

MOB-REL-0008 - Card images are content-addressed, but discarding a card deletes them without checking whether another card uses the same hash

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

Description. `commit` stores image files by sha256 and skips files that already exist ("Idempotent"). Rectification is deterministic, so importing the same gallery photo twice creates two `cards` rows with the same `front_sha256`. `discard(cardId)` calls `store.delete(hash)` without checking whether another live card still references that hash. The other card, which may already be saved to a contact, loses its images.

Undo (`restore`) brings back the card row but not the deleted files.

Remediation. - Delete the files only when no live card references the hash. - Delay file deletion until the undo window has closed.

Verification. Test: create two cards with the same hash, discard one, and assert that the other card's files still exist. Also assert that undo restores the images.

MOB-REL-0009 - No test runs the v1 to v2 to v3 schema upgrade, which every restore of an older backup depends on

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

Description. `onUpgrade` creates `not_duplicates` at v2 and adds 4 columns at v3 (`tables.dart:43-45, 83`). The new columns are nullable or have constant defaults, and the FTS table and indexes are untouched, so static review finds the upgrade correct.

No test, however, opens a v1 or v2 database and upgrades it: - `grep -rn migrat test` finds nothing; - `schema_test.dart` only checks a fresh create; - there are no drift schema dumps.

`backup.dart:168` relies on older backups being "migrated by the normal upgrade", so this untested path runs on every restore of an older backup.

Remediation. Add `drift_dev schema dump` snapshots for v1 to v3 and a `SchemaVerifier` migration test, plus a test that restores a v1 backup fixture.

Verification. The new tests pass in CI.

MOB-SEC-0001 - "Backup scope is undeclared: allowBackup defaults to true with no dataExtractionRules, so the contacts DB, card photos and weekly backup zips go to Google cloud backup and device transfer"

Severity S2 | **Status** open | **Confidence** high | **Basis** artifact | **Blockers** []

MOB-SEC-0002 - "Follow-up reminders show the contact's name, company and event on the lock screen (no visibility or publicVersion set)"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-SEC-0003 - "Camera captures (takePicture files in the cache dir) are read into memory and never deleted"

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

MOB-SEC-0004 - "No FLAG_SECURE or recents protection: contact screens appear in the recents thumbnail and in screenshots"

Severity S0 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-SEC-0005 - "Contacts database, card images and backup zips are stored unencrypted (roadmap decision D3 still open)"

Severity S0 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-SEC-0006 - "Incoming vCard intent reads any URI without checking scheme or authority (confused-deputy read of CardKeep's own private files)"

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

MOB-SEC-0007 - "debugPrint error logging runs in release, and clipboard copies of contact details are not flagged sensitive"

Severity S0 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

MOB-SEC-0100 - "CSV import is quadratic: the separator is re-detected by splitting the whole file at every comma, so a few-thousand-row CSV freezes the app"

Severity S2 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [quality]

MOB-SEC-0101 - "OCR text parser regexes are super-linear on long lines (20k digits 13 s, 50k chars 84 s)"

Severity S1 | **Status** open | **Confidence** medium | **Basis** static | **Blockers** []

MOB-SEC-0102 - "Backup restore trusts the zip's own manifest: unlisted files are staged unverified, the database is not integrity-checked, and there is no size limit"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-SEC-0103 - "Opening a malformed website value (e.g. 'javascript:alert(1)' from a vCard or QR) throws an uncaught FormatException"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-STORE-0001 - "In-app APK self-updater and REQUEST_INSTALL_PACKAGES are not allowed in a Play build"

Severity S3 | **Status** open | **Confidence** high | **Basis** artifact | **Blockers** [store]

Blocks Play submission only. Fine for GitHub Releases.

MOB-STORE-0002 - "Plugin-merged READ_MEDIA_IMAGES/VIDEO/AUDIO and RECORD_AUDIO are declared but no feature needs them"

Severity S3 | **Status** open | **Confidence** medium | **Basis** artifact | **Blockers** [store]

Blocks Play submission (media permissions); least-privilege improvement for GitHub.

MOB-STORE-0003 - "CI builds split APKs only; no AAB and no Play App Signing setup"

Severity S2 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [store]

MOB-STORE-0004 - "No privacy policy URL and no in-app privacy policy link"

Severity S2 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [store]

MOB-STORE-0005 - "Data safety answers not prepared; they depend on the Play build contents"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [store]

MOB-STORE-0006 - "README is stale: 'What it does (0.2.0)', shipped features listed under 'What's next', removed Medium theme named"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** [quality]

MOB-STORE-0007 - "Roadmap still names app id com.axialforge.card_organizer; shipped id com.axialforge.cardkeep becomes permanent at first Play upload"

Severity S1 | **Status** open | **Confidence** high | **Basis** static | **Blockers** []

MOB-UX-0001 - Drawer destinations pile up on the back stack; Back walks through every section visited before leaving the app

Severity S2 | **Status** open | **Confidence** high | **Basis** runtime | **Blockers** []

Description. Opening top-level sections from the navigation drawer pushes each one onto the stack instead of replacing the current section. After visiting Events, Career moves, Review queue, Follow-ups, Duplicates, Tags (and others) via the drawer, system Back steps through each of them in reverse before reaching Contacts and exiting. Some entries (Export and backup, My card, Settings) did not stay on the stack, so the behaviour is also inconsistent between drawer items. Android's navigation principle is that top-level destinations reached from a drawer are siblings: Back from any of them goes to the start destination.

Steps to reproduce. 1. From Contacts open the drawer and visit Events, Career moves, Review queue, Follow-ups, Duplicates, Tags, Export and backup, Settings, Tap cards in turn. 2. Press Back repeatedly.

Expected. Back from a top-level section returns to Contacts; next Back leaves the app. **Observed.** 8 Back presses needed: `1 : MainActivity | Tags 2 : MainActivity | Check the whole library again (Duplicates) 3 : MainActivity | Follow-ups 4 : MainActivity | Scan cards (Review queue) 5 : MainActivity | Career moves 6 : MainActivity | Events 7 : MainActivity | Add contact (Contacts) 8 : NexusLauncherActivity (app left)`

Evidence. Command output above (adb `input keyevent BACK` + `dumpsys window mCurrentFocus` + UI dump per step). Screens: `audit/artifact/screens/20_Events.png` .. `30_Tap_cards_NFC.png`.

Impact. User: confusing, "stuck in the app" feel; growing stack also keeps every visited screen alive in memory. **Recommended remediation.** Use `context.go()` (replace) for drawer destinations, `push` only for detail/sub screens; make all drawer items consistent. **Verification procedure.** Repeat the steps; Back from any drawer section lands on Contacts, then exits.

References. Android "Principles of navigation" (fixed start destination; Back to start from top-level), checked 2026-10-21.

MOB-UX-0002 - "Sync to desktop" is a live drawer entry that opens a "coming in 0.8" placeholder

Severity S1 | **Status** open | **Confidence** high | **Basis** runtime | **Blockers** []

Description. The drawer lists "Sync to desktop" alongside working features. Tapping it opens a screen that only says "Sync to desktop is on the way - This part of the app arrives in version 0.8." Shipping unfinished features as navigable entries reads as broken to users, and Google Play's minimum functionality guidance discourages placeholder content. Low severity because it is clearly labelled and harmless.

Steps to reproduce. Drawer > Sync to desktop. **Expected.** Entry hidden until the feature exists (or clearly marked "Coming soon" in the drawer itself). **Observed.** Placeholder screen.

Evidence. `audit/artifact/screens/27_Sync_to_desktop.png`; UI dump of drawer: `Button Sync to desktop w=308 h=50` (`audit/artifact/screens/02_drawer.png`).

Impact. User: dead end. Business: minor store-review risk once on Play (placeholder features). **Recommended remediation.** Hide the entry behind a feature flag until 0.8, or mark it "Coming soon" in the drawer. **Verification procedure.** Drawer no longer shows the entry (or shows it marked).

References. Google Play "Minimum functionality" policy, checked 2026-10-21.

Coverage & Evidence Matrix

Every control from every domain auditor, merged. States: PASS, PASS-WARN, FAIL, BLOCKED, N/A, NOT TESTED, MANUAL REVIEW. Some auditors used WARN/PARTIAL/NOTE; they count as PASS-WARN (met with a concern) in the totals.

G1-build-supply

Audited artifact: CardKeep-0.6.0-arm64-v8a.apk (v0.6.0, cdcf49d). Tools: aapt2/apksigner/zipalign 36.0.0. Date 2026-10-21. Note: the brief listed "21 Dependencies/SBOM"; in domains.md that control set is domain 18 (21 is logging). Covered as 18.

Domain	Control	State	Basis	Evidence	Finding
02	debuggable off in release	PASS	artifact	manifest-xmltree.txt: no android:debuggable attribute	-
02	Debug endpoints, test credentials, dev menus, mock services, staging URLs absent	PASS	static	Only outbound host api.github.com (updater.dart:106); no staging host found; Appendix A outbound table	-
02	Test ad IDs absent	N/A	static	No ads SDK in pubspec.lock	-
02	Verbose logging off	NOT TESTED	-	Logcat review belongs to logging domain 21 auditor	-
02	Dev certs removed / no user-CA trust	PASS	artifact	No networkSecurityConfig, no cleartext flag; defaults (no user CA for targetSdk 36)	-
02	Signing config correct, dev/prod keys separated	PASS-WARN	artifact	apksigner: verifies, 1 signer, cert matches prior releases (Appendix A); debug-key fallback in build.gradle.kts:47	MOB-BLD-0002
02	Signing scheme	PASS-WARN	artifact	v2 true, v3 false	MOB-BLD-0005
02	Package ID and versioning correct	PASS	artifact	badging: com.axialforge.cardkeep 0.6.0; pubspec 0.6.0+10; release.yml tag-vs-pubspec check	-
02	versionCode scheme across ABI splits monotonic	PASS	artifact	arm64 2010 = 2000+10 (Flutter split offsets 1000/2000/4000 x 1 + build); build number increments per release	-
02	Optimization / minification on	PASS	static	release uses proguard-android-optimize + proguard-rules.pro (Flutter enables R8 for release); ML Kit keep rules present	-
02	Symbols / mapping archived, not shipped	PASS-WARN	artifact	not shipped (unzip -l); not archived either	MOB-BLD-0004
02	No secrets, .env, API keys, private keys in package	PASS	artifact	unzip -l: no .env/.pem/keystore; strings scan for private-key / AIza / ghp_ patterns: no hits	-
02	No secrets in repo / CI	PASS	static	git ls-files: no jks/keystore/key.properties/.env; .gitignore:55-63 and android/.gitignore:78-80 ignore them; CI uses secrets.* only	-
02	No unused permissions	FAIL	artifact	RECORD_AUDIO, READ_MEDIA_VIDEO, READ_MEDIA_AUDIO merged in	MOB-BLD-0001
02	No unused assets	NOT TESTED	-	Asset-by-asset usage not traced; APK 362 entries, 53.4 MB mostly native libs	-
02	APK inventory	PASS	artifact	native-libs.txt (libapp, libflutter, libdartcv, ML Kit OCR + barhopper, libsqlite3); zipalign -c -P 16 OK; extractNativeLibs=false	-
02	Lockfiles committed	PASS	static	pubspec.lock tracked in git	-
02	Reproducible / provenance-tracked CI build	PASS-WARN	static	Built by release.yml on tag, Flutter pinned 3.47.0; no attestation; byte-for-byte rebuild not attempted	MOB-BLD-0003
02	Reproducibility rebuild comparison	NOT TESTED	-	Local OpenCV/NDK rebuild not run in this audit	-
02	Signing-key protection and backup	MANUAL REVIEW	static	keys/ git-ignored, keystore only in GitHub secrets; offline backup location not documented	MOB-BLD-0005
02	Rollback artifact retained	PASS	artifact	Previous APKs remain on GitHub Releases; same key allows reinstall only after uninstall (downgrade blocked by versionCode)	-
03	Fresh install -> launch -> init	NOT TESTED	-	Runtime install flow owned by functional/runtime auditor on emulator	-
03	Auth / configure	N/A	-	No accounts (Appendix A)	-
03	Upgrade previous release -> candidate: DB schema migration	PASS	static	database.dart:32 schemaVersion 3; onUpgrade:47-53 adds table (from<2) and columns (from<3), additive only	-
03	Upgrade: prefs, caches, user files retained	PASS	static	Same applicationId and signing key; card files in app_flutter/cards untouched by migration	-
03	Upgrade path via in-app updater integrity	PASS-WARN	static	updater.dart:157-160 https + GitHub host allow-list; :161-163 refuses when neither SHA-256 nor size known; :185-187 SHA-256 check; size-only when digest absent; Android verifies same signer	-
03	Failed-migration recovery	MANUAL REVIEW	static	No try/rollback around onUpgrade; drift runs it in a transaction; pre-restore copy exists only for restore (CLAUDE.md:121)	-
03	Encryption migration / credentials retained	N/A	-	No encryption or tokens	-
03	Upgrade after inactivity, large data, near-full storage	NOT TESTED	-	Runtime only	-
03	Removal / reinstall: what persists (cloud backup, shared storage)	FAIL	artifact	Auto Backup default on; exports written via SAF/share persist by design	MOB-AND-0001
03	Keystore / device IDs / auth state persistence	N/A	-	None used	-
18	Inventory SDKs, native libs, packages incl. transitive	PASS	static	audit/B-sbom.md from pubspec.lock + native-libs.txt	-
18	Versions and age (outdated)	PASS-WARN	static	`flutter pub outdated` 2026-10-21: direct go_router 18.1.0->18.1.1, ndef_record 1.4.2 (1.5.0 not resolvable); 21 transitive behind, incl. sqlite3 3.5.2->3.7.1, dartcv4 2.2.2->2.3.1	-
18	Known vulnerabilities	MANUAL REVIEW	static	No pub.dev advisory surfaced by pub tooling on 2026-10-21; no external CVE DB lookup (OSV/GHSA) done for bundled native SQLite/OpenCV versions	-
18	Licences	PASS	static	All BSD/MIT/Apache-2.0 for shipped code; dbus MPL-2.0 is Linux-only (not in APK); ML Kit under Google ML Kit terms; licences shown via Flutter LicensePage expected	-

Domain	Control	State	Basis	Evidence	Finding
18	Maintainer / deprecation / abandonment	PASS-WARN	static	sqlite3_flutter_libs 0.6.0+eol and sqlcipher_flutter_libs 0.7.0+eol are end-of-life stub packages (native lib now via sqlite3 build hooks); remove when drift_flutter allows	-
18	Ad / analytics / auth / crypto libraries	PASS	static	None besides crypto (SHA-256); firebase-components present only as ML Kit internals, no Firebase services	-
18	Necessity	PASS	static	Every direct dependency maps to a feature in Appendix A stack	-
18	SBOM (CycloneDX/SPDX)	PASS-WARN	static	Table SBOM produced (B-sbom.md); no machine-readable SBOM in CI	MOB-BLD-0003
18	Lockfile integrity and pinned versions	PASS	static	pubspec.lock committed with sha256 per hosted package; CI runs pub get against it	-
18	CI supply chain (action pinning)	FAIL	static	Actions pinned by major tag	MOB-BLD-0003

Counts: PASS 18, PASS-WARN 8, FAIL 3, MANUAL REVIEW 3, NOT TESTED 5, N/A 4, BLOCKED 0 (total 41).

G2-local-platform

Runtime checks: the emulator's `dumpsys package` returned "Can't find service: package" during this pass, so runtime-only controls are static and capped at PASS-WARN, or BLOCKED.

Domain	Control	State	Basis	Evidence	Finding
12	Backup flags (allowBackup / dataExtractionRules / fullBackupContent)	FAIL	artifact	manifest-xmltree.txt:101-106 no attributes	MOB-SEC-0001
12	adb backup extraction	PASS-WARN	artifact	targetSdk 36: adb backup excluded on Android 12+; still possible on API 24-30 devices because allowBackup defaults to true	MOB-SEC-0001
12	Database at rest (encryption)	WARN	static	drift/SQLite plaintext, app-private; D3 open	MOB-SEC-0005
12	Storage location (app-private, no external storage)	PASS-WARN	static	app_flutter/ paths (A architecture); no WRITE_EXTERNAL_STORAGE in manifest; exports via SAF/share only	-
12	Card images stored as files	PASS-WARN	static	lib/core/images/image_store.dart app_flutter/cards/.jpg, pending cleanup :53,:68	-
12	Temp files: OCR / region jpg	PASS-WARN	static	lib/scan/scan_pipeline.dart:194-221 deleted in finally	-
12	Temp files: camera capture	FAIL	static	scan_screen.dart:239-255 never deleted	MOB-SEC-0003
12	Temp files: VACUUM INTO backup copy	WARN	static	backup.dart:40-44 no finally	MOB-SEC-0003
12	Update APK temp	PASS-WARN	static	updater.dart:164-188 deletes on failure/retry	-
12	Exported backup zip confidentiality	WARN	static	backup.dart:38-50 plaintext zip	MOB-SEC-0005
12	Restore zip path traversal (stage)	PASS-WARN	static	backup.dart:121-124 normalize + isWithin, skips escapes; hashes checked in check()	-
12	Restore safety copy	PASS-WARN	static	backup.dart:170-186 before_restore/ kept	-
12	Restore zip size / decompression cap	WARN	static	backup.dart:121 decodeBytes of whole zip with no size cap (zip bomb could OOM; user-chosen file, so low); referred to the domain 08/10 auditor	-
12	Clipboard	WARN	static	contact_detail_screen.dart:418, tap_screen.dart:238 not marked sensitive	MOB-SEC-0007
12	Screenshots / recents (FLAG_SECURE)	WARN	static	not set; acceptable until app lock S15.2	MOB-SEC-0004
12	Logs on device (print/debugPrint PII)	PASS-WARN	static	4 debugPrint of exceptions only; no print() in lib/	MOB-SEC-0007
12	Keyboard cache on sensitive fields	N/A	static	no password/secret fields (no auth)	-
12	Secrets/keys stored on device	N/A	static	none (no backend, no auth; A scope)	-
PLATFORM	Exported components inventory	PASS-WARN	artifact	manifest-xmltree.txt: only MainActivity exported=true plus androidx ProfileInstallerReceiver (exported, permission DUMP, :264-268); all providers/services/other receivers exported=false	-
PLATFORM	FileProvider / share providers	PASS-WARN	artifact	providers :166-196 exported=false, grantUriPermissions=true; share via XFile.fromData (contacts_screen.dart:137, contact_detail_screen.dart:66, my_card_screen.dart:113)	-
PLATFORM	VIEW/SEND vCard intent handling (readVcf)	WARN	static	MainActivity.kt:47-70 no scheme/authority check; BROWSABLE on VIEW	MOB-SEC-0006
PLATFORM	Incoming payload size cap (1 MB)	PASS-WARN	static	MainActivity.kt:62; vcard_reader.dart:7 maxFilePayload	-
PLATFORM	Imports need user confirmation	PASS-WARN	static	A entry points: Import screen confirm (UI verified by the functional auditor)	-
PLATFORM	Deep links / App Links	N/A	artifact	flutter_deeplinking_enabled=false; no http(s) intent filter	-
PLATFORM	Boot receiver protection	PASS-WARN	artifact	ScheduledNotificationBootReceiver exported=false (AndroidManifest.xml:59)	-
PLATFORM	Notification content / lock screen	WARN	static	reminders.dart:65-80 PII, default visibility	MOB-SEC-0002
PLATFORM	Notification payload handling	PASS-WARN	static	payload = person id only (reminders.dart:80), opens /contact/	-
PLATFORM	WebView	N/A	static	no webview_flutter / WebView in pubspec or lib	-
PLATFORM	URL launching (QR / contact links)	PASS-WARN	static	link_launcher.dart:11 externalApplication only; qr_content.dart:85 non-https warning; opened on tap only	-
PLATFORM	Package visibility ()	PASS-WARN	static	AndroidManifest.xml queries limited to PROCESS_TEXT, VIEW http/https/geo, DIAL, SENDTO mailto/sms	-
PLATFORM	Pending intents / implicit internal intents	PASS-WARN	static	MainActivity only starts system NFC/Wireless settings intents	-
PLATFORM	Tapjacking / overlay protection	N/A	static	no sensitive confirm actions beyond in-app dialogs; not required at L1	-
19	Debuggable flag (release)	PASS-WARN	artifact	manifest-xmltree.txt application has no debuggable attribute (false)	-
19	Code shrinking / obfuscation	PASS-WARN	artifact	android/app/build.gradle.kts:49 proguard-android-optimize (Flutter release runs R8); classes.dex 4.25 MB; Dart AOT snapshot is not symbolised by --obfuscate (not used; acceptable, no secrets)	-
19	Root / emulator / hook detection	N/A (accepted)	static	none; local app with no secrets, acceptable at L1	-
19	Integrity / anti-tamper (Play Integrity, signature check)	N/A (accepted)	static	none; distribution on GitHub with a stable signing key (A identity)	-

Domain	Control	State	Basis	Evidence	Finding
19	Native libs extracted (extractNativeLibs=false)	PASS	artifact	manifest-xmltree.txt:101	-

Counts: 37 controls. PASS 1, PASS-WARN 20, WARN 8, FAIL 2, N/A 6 (2 accepted). BLOCKED none; runtime confirmation of the backup contents (bmgr) and the lock-screen notification is listed for Phase 22.

G3-network-input

Domain	Control	State	Basis	Evidence	Finding
13	Cleartext traffic disabled	PASS	artifact	Merged manifest `audit/artifact/manifest-xmltree.txt`: no usesCleartextTraffic, targetSdk 36 (default false)	-
13	Network security config (no user-CA trust, no debug overrides)	PASS	artifact	No networkSecurityConfig attribute; platform default (system CAs only)	-
13	All endpoints HTTPS	PASS	static	updater.dart:106 Uri.https; :158 scheme == https	-
13	Certificate pinning	N/A	static	Public GitHub endpoints, no secrets sent; pinning not warranted	-
13	No identifiers/PII in requests	PASS	static	updater.dart:107 only Accept + User-Agent headers	-
13	Timeouts on network calls	PASS	static	updater.dart:109 (12 s), :167 (20 s connect)	MOB-REL-0004 (stream errors)
14	Update host allow-list	PASS	static	updater.dart:157-159	-
14	Update integrity (SHA-256)	PARTIAL	static	updater.dart:149, 161, 185-190 size-only fallback	MOB-API-0001
14	Download size limit	FAIL	static	updater.dart:173-177 unbounded	MOB-API-0001
14	Redirect handling	PASS	static	package:http follows redirects over TLS to GitHub CDN; initial host checked	-
14	Downgrade / wrong-signer protection	PASS	static	updater.dart:58 newer-only; Android installer enforces same signer + versionCode	-
14	Draft/prerelease excluded	PASS	static	updater.dart:122-128	-
14	Rate-limit handling	PASS	static	updater.dart:114-116	-
14	Install path (REQUEST_INSTALL_PACKAGES / open_filex)	PASS	static	updater.dart:197-206; user confirms in system installer	-
14	Version comparison robustness	PASS	static	updater.dart:15-35 BigInt parts, pre-release ordering	-
CODE	vCard reader size cap	PASS	static	vcard_reader.dart:7,14 (1 MB), field truncation :175	-
CODE	MECARD size cap	PASS	static	vcard_reader.dart:79 (8 KB)	-
CODE	CSV import complexity / size cap	FAIL	static+test	csv_import.dart:51,71-74; probe 10k rows 105 s	MOB-SEC-0100
CODE	NFC NDEF parsing / link schemes	PASS	static	ndef.dart:193-197 only http(s)/tel accepted; vCard capped	-
CODE	QR classification / link warnings	PASS	static	qr_content.dart:15-32 http(s) only; LinkCheck :82-92 (punycode, IP, shortener, userinfo)	-
CODE	Backup zip path traversal	PASS	static	backup.dart:123-124 normalize + isWithin	-
CODE	Backup zip bomb / size limit	FAIL	static	backup.dart:81,121 full in-memory decode; transfer_screens.dart:289	MOB-SEC-0102
CODE	Backup manifest trust / DB validation	PARTIAL	static	backup.dart:100-105 vs 121-127	MOB-SEC-0102
CODE	Backup newer-schema refusal	PASS	static	backup.dart:94-97	-
CODE	OCR parser ReDoS	PARTIAL	test	rules.dart:55,60,203; 50k chars 84 s	MOB-SEC-0101
PLATFORM	.vcf intent handler size cap	PASS	static	MainActivity.kt:65 (1 MB)	-
PLATFORM	.vcf intent URI scheme check	FAIL	static	MainActivity.kt:49-55	MOB-SEC-0006 (G2)
PLATFORM	url_launcher dangerous schemes (javascript:, intent:, file:)	PASS	static+test	link_launcher.dart:45-48 forces https://; tel/sms sanitised :50; external app mode	-
PLATFORM	url_launcher malformed input handling	FAIL	test	FormatException outside try	MOB-SEC-0103
PLATFORM	Deep links	N/A	artifact	flutter_deeplinking_enabled=false (Appendix A)	-
CODE	SQL injection in raw customSelect/customStatement	PASS	static	contacts_repository.dart:21-40 bound vars; FTS via ftsQuery + `?`; duplicates_repository.dart:295 `$table` from code constants only	-
CODE	Notification payload trust	PASS	static	payload = person id routed to /contact/ (Appendix A); unknown id shows nothing	-

Counts: PASS 22, PARTIAL 3, FAIL 5 (one is G2's MOB-SEC-0006), N/A 2. Total 32. No WebSearch used.

G4-privacy

Domain	Control	State	Basis	Evidence	Finding
16	Data-flow inventory built (every data class)	Pass	static	audit/B-inventories.md	-
16	No account; account deletion requirement	N/A	static	A-scope: no auth	-
16	No ads / analytics / crash SDK	Partial	artifact	pubspec.lock clean; ML Kit datatransport present	MOB-PRV-0001
16	Declared vs actual network use (README, Settings)	Fail	artifact	README.md:50-53; settings_screen.dart:161,186	MOB-PRV-0001
16	Card photos stored without EXIF	Pass	static	card_detector.dart:168-174; image_store.dart:7-9; pickMultiImage(requestFullMetadata:false) scan_screen.dart:294	-
16	Temp/capture files removed	Fail	static	scan_screen.dart:252-253; scan_pipeline.dart:200,221 delete OCR temps; backup.dart:44 deletes VACUUM temp	MOB-SEC-0003
16	Contact delete removes personal data	Fail	static	contacts_repository.dart:343-346; database.dart:61-67	MOB-PRV-0002
16	Card images deleted with card (queue)	Partial	static	card_queue_repository.dart:121-129 (images yes, logo no)	MOB-PRV-0002
16	Backups exclude deleted data	Fail	static	backup.dart:42 VACUUM INTO	MOB-PRV-0002
16	Exports exclude deleted data	Pass	static	transfer_repository.dart:82	-
16	Auto backups bounded retention	Pass	static	backup.dart:136-155 keep=4	-
16	before_restore fallback retention	Fail	static	backup.dart:168-186	MOB-PRV-0003
16	OS cloud backup scope declared	Fail	artifact	manifest-xmltree.txt line=101 no allowBackup	MOB-AND-0001, MOB-SEC-0001

Domain	Control	State	Basis	Evidence	Finding
16	Data at rest encryption	Partial	static	unencrypted SQLite (decision open)	MOB-SEC-0005
16	Data leaves device only on user action (share/export/SAF)	Pass	static	SharePlus calls contacts_screen.dart:134, contact_detail_screen.dart:63, my_card_screen.dart:110, transfer_screens.dart:52	-
16	Update check sends no identifiers, off by default	Pass	static	settings_screen.dart:155-163; A-scope outbound table	-
16	Lock-screen notification content	Fail	static	reminders.dart:65-79	MOB-SEC-0002
16	Recents/screenshot exposure	Partial	static	no FLAG_SECURE	MOB-SEC-0004
16	Privacy policy exists and linked	Fail	static	ROADMAP.md:546, :496	MOB-STORE-0004
16	Data Safety answers prepared	Partial	static	draft in B-inventories.md	MOB-STORE-0005, MOB-PRV-0001
16	Debug OCR capture screen (writes to external app dir) unreachable in release	Pass	static	drawer.dart:147 kDebugMode; deep links disabled	-
17	Merged manifest permission inventory	Pass	artifact	B-inventories.md Permissions	-
17	Minimum necessary permissions	Fail	artifact	manifest-xmltree.txt lines 82-92	MOB-BLD-0001, MOB-STORE-0002, MOB-PRV-0004
17	REQUEST_INSTALL_PACKAGES justified for channel	Partial	artifact	ok for GitHub build; not allowed on Play	MOB-STORE-0001
17	Camera requested in context (on opening Scan)	Pass	static	camera plugin request at controller init, scan_screen.dart:140-160	-
17	Camera denial handled (denied state, gallery still works)	Pass	static	scan_screen.dart:160-165	-
17	Camera allow / deny / don't-ask-again at runtime	Blocked	-	emulator runtime run belongs to G-runtime; phone camera not connected	-
17	Notification permission requested in context (first future follow-up)	Pass	static	reminders.dart:58-62	-
17	Notification denial degrades gracefully	Pass	static	requestPermission result ignored; app works without reminders	-
17	In-app rationale before notification prompt	Partial	static	none shown; system prompt is contextual enough	-
17	NFC not required, foreground reader mode only	Pass	artifact	AndroidManifest.xml:4-5 required=false; no NFC intent filter	-
17	Camera feature not required	Pass	static	AndroidManifest.xml:14	-
17	RECEIVE_BOOT_COMPLETED receiver not exported	Pass	artifact	A-scope entry points	-
17	Location / contacts / phone permissions	N/A	artifact	not requested	-
18	No PII in release logs	Partial	static	debugPrint scan_screen.dart:260, main.dart:18, scan_pipeline.dart:159,180; no print()	MOB-SEC-0007
18	Telemetry matches declarations	Fail	artifact	datatransport in merged manifest	MOB-PRV-0001
18	Crash/error reporting (supportability)	Partial	static	none by design; user-visible error messages only; symbols not archived	MOB-BLD-0004
18	Logcat check at runtime	Blocked	-	not run in this part; needs emulator logcat during failed scan	-

Totals (38 controls): Pass 15, Partial 9, Fail 10, N/A 2, Blocked 2. Domain 18 here maps to domains.md section 21 (Logging, telemetry, supportability).

G5-functional

Auditor G5. Release 0.6.0 (2010), commit cdcf49d. These domains are numbered as in `references/domains.md`: 04 is functional completeness, 11 is reliability and failure (which includes data integrity here), 20 is offline. The brief's "05 functional correctness" and "10 reliability" labels are mapped onto 04 and 11.

Automated results

Check	Result
`flutter test` (full suite, run 2026-10-21)	**162 passed, 2 skipped, 0 failed** ("All tests passed!")
`flutter analyze`	14 issues, all `info` level. Some come from the temporary `test/audit_tmp/` probe files, which were deleted afterwards. No errors or warnings were reported.

Coverage

Domain	Control	State	Basis	Evidence	Finding
04	Feature inventory built from roadmap, changelog, router and drawer	PASS	static	Inventory below; `lib/app/router.dart:40-104`, `lib/app/drawer.dart:18-38`	-
04	Unit/widget tests for the core features	PASS	static+test	162 passed, 2 skipped	-
04	Unbuilt features are labelled, not broken	PASS	static	`/sync` is shown as ComingSoon (milestone 0.8), `router.dart:100-104`	-
04	Interrupted and cancelled paths: batch scan	FAIL	static	`scan_worker.dart:36-41`, `scan_pipeline.dart:122-134`	MOB-REL-0002
04	Retry path: update download	FAIL	static	`update_sheet.dart:41-57`	MOB-REL-0004
04	Duplicate path: same photo imported twice, then discard	FAIL	static	`card_queue_repository.dart:120-131`	MOB-REL-0008
04	Every interactive control exercised at runtime	NOT TESTED	-	Runtime pass is owned by the UX/runtime auditor; widget flow `test/features/contacts_flow_test.dart` only	-
11	Schema migration v1 to v2 to v3 is correct	PASS	static	`database.dart:47-55`; added columns are defaulted or nullable (`tables.dart:43-45, 83`)	-
11	Migration is covered by a test	FAIL	static	No migration test, no schema dumps	MOB-REL-0009

Domain	Control	State	Basis	Evidence	Finding
11	Restore: backup verified before staging (hashes, newer schema, zip-slip)	PASS	static+test	`backup.dart:81-121, 129-133`; `test/transfer/transfer_test.dart:193-201`	-
11	Restore swap survives being killed partway	FAIL	static+test	`backup.dart:170-187`	MOB-REL-0001
11	Restore failure is reported and rolled back; fallback reachable	FAIL	static	`main.dart:15-19`; no UI references `before_restore`	MOB-REL-0003
11	Second restore overwrites before_restore	PARTIAL	static	`backup.dart:173`; by design only one level of fallback (covered under MOB-REL-0003)	MOB-REL-0003
11	Merge and undo are atomic	PASS	static+test	`duplicates_repository.dart:117, 252` use `db.transaction`; `test/dupes/merge_test.dart`	-
11	Retire / moveFollowup are atomic	PASS	static	`career_repository.dart:243, 341, 410`	-
11	Career changeJob is atomic	FAIL	static	`career_repository.dart:266-330` has no transaction	MOB-REL-0006
11	Import merge is atomic and idempotent	PARTIAL	static	`transfer_repository.dart:157-196`; re-running is safe thanks to matching, but there is no transaction	MOB-REL-0006
11	Tag delete is atomic	PASS	static	`tags_repository.dart:104`	-
11	Event delete is atomic and keeps links	PARTIAL	static	`events_repository.dart:116-122` keeps the people links but uses two statements	MOB-REL-0006
11	Contact delete is a tombstone with undo	PASS	static+test	`contacts_repository.dart:343-349`; flow test "delete from detail with undo"	-
11	Scan-queue crash recovery	FAIL	static	`scan_worker.dart:44-50` sees only `pending/`; queued jobs are held in RAM	MOB-REL-0002
11	A capture that keeps failing is handled	FAIL	static	`scan_worker.dart:71-73`	MOB-REL-0005
11	Image store: no shared-file deletion	FAIL	static	`image_store.dart:66-70`	MOB-REL-0008
11	Follow-up rescheduling	PASS	static+test	`followups_repository.dart:76`; `test/followups/followups_repository_test.dart`	-
11	Reminder ids and cancelAll side effects	PARTIAL	static	`reminders.dart:52, 62`	MOB-REL-0007
11	Silent `catch (_) {}` sites	PARTIAL	static	`app.dart:70, 108, 117, 127` are startup niceties (acceptable). `card_queue_repository.dart:98` (logo) is acceptable. `scan_worker.dart:71` hides failures (MOB-REL-0005). `main.dart:17` hides a restore failure (MOB-REL-0003)	MOB-REL-0003, MOB-REL-0005
11	Unawaited futures	PASS	static	Only navigation pushes, haptics and the `ScanWorker._run` loop, which catches its own errors (`scan_worker.dart:40, 53-82`)	-
11	Auto backup rotation	PASS	static	`backup.dart:136-157`; keeps 4; excludes `cards/pending`	-
11	Fault injection at runtime (low storage, revoked permission, reboot)	NOT TESTED	-	Emulator runtime is owned by another group; phone-only items are BLOCKED	-
20	App works fully offline (no network needed outside update)	PASS	static	The only HTTP client is `lib/core/update/updater.dart` (see Appendix A)	-
20	Update check offline fails gracefully	PASS	static+test	`updater.dart:103-117` maps errors to `UpdateException`; startup is silent (`app.dart:93`); `test/update/updater_test.dart`	-
20	Update download offline or interrupted	FAIL	static	`updater.dart:166-176`	MOB-REL-0004
20	Network change mid-download / stall timeout	FAIL	static	No idle timeout on the stream	MOB-REL-0004
20	Airplane-mode runtime check	NOT TESTED	-	Runtime group	-

Counts: 35 controls. PASS 15, FAIL 12, PARTIAL 5, NOT TESTED 3.

Feature inventory

Feature	Where (entry point)	Tests	Verified how
Contacts list, search (FTS5), detail, edit, delete with undo	`/`, `/contact/:id`, `/contact/:id/edit`; `contacts_repository.dart`	yes (`contacts/`, `features/contacts_flow_test.dart`)	test + static
New contact (manual or from scan)	`/contact/new`	yes	test
Card scan (camera, single/pile, gallery import, manual crop)	`/scan`, `/scan/crop`; `scan_pipeline.dart`, `scan_worker.dart`	partial (`scan/` detector, geometry, ML Kit fixture; no worker test)	static (MOB-REL-0002, -0005)
Card parser (OCR to fields, v3 fields)	`lib/scan`, parser	yes (`parser/`, `core/fields_v3_test.dart`)	test
Review queue, auto-save of clean cards	`/queue`; `card_queue_repository.dart`	yes (`cards_queue/`)	test + static (MOB-REL-0008)
NFC tap (NDEF read/write, My card)	`/tap`, `/mycard`	yes (`nfc/ndef_test.dart`)	test; hardware BLOCKED (phone)
Duplicates detect, merge, undo, not-a-duplicate	`/duplicates`, `/merge/:a/:b`	yes (`dupes/`)	test + static
Career moves (suggestions, change job, retire, succession)	`/career`; `career_repository.dart`	yes (`career/`)	test + static (MOB-REL-0006)
Events and scan sessions (auto-start, met-at)	`/events`, `/event/:id`	yes (`events/`)	test + static
Follow-ups and reminders	`/followups`; `reminders.dart`	repository yes; reminders plugin no	test + static (MOB-REL-0007)
Tags (system and user, bulk)	`/tags`	yes (`tags/`)	test

Feature	Where (entry point)	Tests	Verified how
Import vCard / CSV with saved mapping, share-to-import	`/import`, `/import/csv`, intent channel	yes (`vcard/`, `transfer/`)	test + static
Export (vCard/CSV) and backup/restore, weekly auto backup	`/export`; `backup.dart`	yes (`transfer/transfer_test.dart`)	test + static (MOB-REL-0001, -0003)
In-app update (GitHub Releases)	Settings > update sheet; `updater.dart`	yes, check path (`update/`)	test + static (MOB-REL-0004)
Settings (theme, auto save, auto backup, update on start, search engine)	`/settings`	partial (flow test, web search engine)	test
OCR debug capture	`/debug/ocr`	no	static (route is registered in release builds)
Sync to desktop	`/sync` (ComingSoon, 0.8)	n/a	static: placeholder

G6-store

Policies checked 2026-10-21 (sources in C-store-device-open-items.md).

Domain	Control	State	Basis	Evidence	Finding
22	Apple App Store review guidelines (all)	N/A	static	iOS out of scope (Appendix A)	-
23	Target API level (36 required for new apps/updates by 2026-08-31)	PASS	artifact	badging.txt targetSdkVersion 36	-
23	16 KB page size: zip alignment	PASS	artifact	zipalign -c -P 16 -v 4: Verification successful on all 3 APKs	-
23	16 KB page size: ELF LOAD alignment (arm64)	PASS	artifact	llvm-readelf: all .so LOAD align 0x4000 or 0x10000	-
23	AAB format and Play App Signing	FAIL	static	release.yml:49 APK only	MOB-STORE-0003
23	REQUEST_INSTALL_PACKAGES / self-update (Device and Network Abuse)	FAIL (Play only)	artifact	manifest line 21; updater.dart	MOB-STORE-0001
23	Photo and Video Permissions (READ_MEDIA_IMAGES/VIDEO)	FAIL (Play only)	artifact	manifest lines 90-92	MOB-STORE-0002
23	Microphone (RECORD_AUDIO) unused	FAIL	artifact	manifest line 82	MOB-STORE-0002
23	Camera permission justified by feature	PASS	static	card scanning	-
23	NFC permission justified	PASS	static	Tap cards (0.6.0)	-
23	POST_NOTIFICATIONS runtime request	PASS (static)	static	follow-up reminders; runtime prompt owned by permissions domain	-
23	Exact alarm permission (SCHEDULE_EXACT_ALARM / USE_EXACT_ALARM)	PASS	artifact	not declared; inexact alarms	-
23	Foreground service types	N/A	artifact	no FOREGROUND_SERVICE permission; services are plugin, non-FGS	-
23	Privacy policy URL + in-app link	FAIL	static	settings_screen.dart:185 no link	MOB-STORE-0004
23	Data safety section	NOT STARTED	static	no Play app	MOB-STORE-0005
23	Account deletion	N/A	static	no accounts	-
23	Families / target audience	N/A (declare 18+/adult business audience)	static	business tool	-
23	Content rating questionnaire	MANUAL	-	to do in Play Console	-
23	Package name final	OPEN	static	ROADMAP S0.14 stale	MOB-STORE-0007
23	Ads / billing / UGC policies	N/A	static	none present	-
21	README feature list matches build	FAIL	static	README 0.2.0 vs CHANGELOG 0.6.0	MOB-STORE-0006
21	README privacy claims	PASS	static	consistent with Appendix A network surface	-
21	GitHub description and topics	PASS	static	gh repo view	-
21	In-app privacy text ("No account, no cloud, no analytics")	PASS	static	settings_screen.dart:187	-
23	GitHub distribution (sideload) readiness	PASS	artifact	signed, same key as prior releases, updater user-started	-

Counts: PASS 13, FAIL 7, N/A 6, OPEN/NOT STARTED/MANUAL 3 (29 controls).

G7-ux-perf

Runtime on emulator-5554 (Pixel_10_Pro_XL_test, Android 16 / API 37 image reporting SDK 37, 1344x2992 @ 480 dpi) with the shipped `CardKeep-0.6.0-x86_64.apk`. 3 contacts (2 via vCard import, 1 by hand with very long fields).

Domain	Control	State	Basis	Evidence	Finding
06	All drawer screens open and render (Contacts, Events, Career moves, Review queue, Follow-ups, Duplicates, Tags, Import, Export and backup, Sync, My card, Settings, Tap cards, Scan, detail, edit)	PASS	runtime	screens/01..30	-
06	Placeholder / unfinished features reachable	FAIL	runtime	screens/27_Sync_to_desktop.png	MOB-UX-0002
06	Long text overflow (very long name, title, company) at 1.0 / 2.0 font	PASS	runtime	screens/09_detail_long.png, 54_font200_detail.png, 55_font200_contacts.png	-
06	Dark theme rendering	PASS	runtime	screens/60_dark_contacts.png, 61_dark_detail.png, 62_dark_export.png	-

Domain	Control	State	Basis	Evidence	Finding
06	Landscape rendering / scrolling	PASS (not locked; header scrolls away, list usable)	runtime	screens/40_landscape_contacts.png, 41_landscape_scrolled.png	-
07	Empty states (Contacts, Events, Notes, Tags, My card, Review)	PASS	runtime	screens/01_launch_empty.png, 20_Events.png, 28_My_card.png	-
07	Error/unavailable state (no NFC)	PASS	runtime	screens/30_Tap_cards_NFC.png ("No NFC on this phone")	-
07	Destructive/import confirmation	PASS (Import 2 contacts? Cancel/Import)	runtime	screens/05_import_preview.png	-
07	Back navigation	FAIL	runtime	back-stack walk output	MOB-UX-0001
07	TalkBack labels on icon buttons	PASS (all icon-only controls had content-desc in dumps)	runtime	UI dumps, all screens	-
07	Text field labels	PASS (visible floating labels/hints; dump EditText text empty is a uiautomator limitation for Flutter hints)	runtime	screens/08_edit_new.png	-
07	Touch targets >= 48 dp	FAIL	runtime	UI dumps	MOB-A11Y-0001, MOB-A11Y-0002
07	Large font 1.3 and 2.0	PASS (wraps/ellipsizes, no clipping; icons do not scale, acceptable)	runtime	screens/50..55	-
07	Contrast	PASS (tokens tested in test/app/theme_test.dart; visual check light+dark; disabled Email exempt)	static+runtime	theme_test.dart, 09/61 screens	-
07	Permission prompt in context	PASS (camera asked on entering Scan)	runtime	screens/12_scan_perm.png	-
08	minSdk 24 / target 36	PASS (static; API 24-35 devices not run)	static	A-scope identity table	-
08	Orientation lock	PASS (none; configChanges handled)	artifact	manifest-xmltree.txt:110	-
08	ABI coverage (arm64, armv7, x86_64 splits)	PASS	artifact	audit/artifact/*.apk	-
08	Older API levels / real device (S25 Ultra), NFC, real camera	BLOCKED (not available in this run)	-	-	-
09	Cold start	PASS (742-886 ms warm-cache cold; 1621 ms first after install)	runtime	am start -W	-
09	APK size per ABI	PASS with note (53.4/41.7/59.6 MB; ML Kit + OpenCV bundled)	artifact	audit/artifact	-
09	Memory idle / Scan	NOTE	runtime	dumpsys meminfo	MOB-PERF-0001
09	Jank / frame timing	BLOCKED (dumpsys gfxinfo sees only 4 frames: Flutter renders through its own surface; profile-mode DevTools needed)	runtime	gfxinfo output	-
09	Large-library scroll (big5k)	BLOCKED (release build cannot be seeded; no run-as)	-	-	-

Counts: 24 controls - 17 PASS, 3 FAIL, 1 NOTE, 3 BLOCKED (one BLOCKED row covers older APIs/real device). Findings: 5.

Appendix A: Scope, method, identity and attack surface

Scope (Phase 0)

Item	Decision	Evidence
Platform	**Android only**	`android/` configured (applicationId, release signing, CI release job). `ios/` is unmodified Flutter scaffolding; iOS is "later" in `docs/ROADMAP.md` (S14.4). iOS: out of scope.
Backend/API (domains 13, 14)	**N/A** except the update check	No server of our own. Only outbound call is the user-started (or opt-in at launch) GitHub Releases check and APK download (`lib/core/update/updater.dart`). Treated as a network surface in domain 13.
Accounts / authentication (15)	**N/A**	No sign-up or sign-in anywhere; code search finds no auth SDK. App lock is planned (S15.2) and not yet built.
Payments / billing	**N/A**	No billing dependency in `pubspec.yaml` or Gradle.
Ads / analytics / crash reporting	**N/A** (verified)	No ads, analytics, Firebase or crash SDK in `pubspec.lock` (checked in domain 21).
User-generated content shared with others	**N/A**	Single-user, on-device.
Threat model	Personal contact data (names, phones, emails, addresses, card photos, notes) on one phone. Main risks: data loss, other apps or backups reading it, a malicious file/tag/QR/update, over-broad permissions, store-policy rejection. Physical attacker with an unlocked phone is out of scope (no app lock yet; S15.2).	

Evidence mode

Artifact + runtime. The audited artifacts are the APKs CI attached to GitHub Release v0.6.0, plus runtime checks on the Android emulator (Pixel_10_Pro_XL_test, Android 16 x86_64) with the same release's x86_64 APK. The owner's phone (Galaxy S25 Ultra) is not connected for this audit; phone-only behaviour (NFC, real camera) is BLOCKED and listed for the phone test sheets.

Identity (Phase 1, domain 01)

Field	Value
App name	CardKeep
Package	com.axialforge.cardkeep
Version	0.6.0, versionCode 2010 (arm64 split: 2000 + 10)
Commit / tag	cdcf49d38afbb9ed672840c442cdd2dfc76b0db0 / v0.6.0 (clean tree)
minSdk / targetSdk / compileSdk	24 / 36 / 37
Signing	Signer DN `CN=AxialForge, O=AxialForge, C=US`, cert SHA-256 `4ffa7fe0…3a2820`; same key as earlier releases (in-place updates work)
Distribution	GitHub Releases (public repo AxialForge/cardkeep); Google Play not yet (M9)
Artifacts (SHA-256)	arm64-v8a `CC9B63BC…F52501` (53.4 MB); armeabi-v7a `A2446A3F…8E564` (41.7 MB); x86_64 `B94EFE3C…AA9EF7` (59.6 MB)
Stack	Flutter 3.47 / Dart 3.13, drift (SQLite + FTS5), Riverpod, go_router, camera, opencv_dart, ML Kit text + barcode (bundled models), nfc_manager, flutter_local_notifications, file_picker, archive, share_plus, url_launcher, qr_flutter
Data classes	Contact identity and contact details (name, title, company, phone, email, address, website), card photos, notes, tags, events, follow-up dates, own card (My card)

Identity gate: PASS. Audited APKs are exactly the release assets for tag v0.6.0 at commit cdcf49d; signing certificate matches previous releases.

Architecture (Phase 2)

`Camera / gallery / NFC / .vcf / .csv / .zip -> Flutter UI -> parsers (OCR, QR, vCard, CSV, NDEF) -> repositories (drift) -> SQLite file app_flutter/card_organizer.sqlite (app-private) -> card images app_flutter/cards/{original,rectified,thumb,logo}/<sha256>.jpg -> exports/backups -> share sheet or Storage Access Framework (user picks destination) Network: only Settings > Updates -> api.github.com (release list) -> github.com/objects.githubusercontent.com (APK)`

Entry points

Entry point	Where	Notes
Launcher activity	MainActivity (exported, MAIN/LAUNCHER)	
VIEW `text/x-vcard`, `text/vcard`, `text/directory` (content scheme)	MainActivity intent filter	File read by `MainActivity.readVcf`, capped 1 MB, handed to Import (user confirms)
SEND `text/x-vcard`, `text/vcard`	MainActivity intent filter	Same path
Notification tap	flutter_local_notifications	payload = person id; opens `/contact/<id>`
Boot completed / package replaced	ScheduledNotificationBootReceiver (exported=false)	Re-schedules reminders
NFC reader mode	Tap screen only, foreground	No NFC intent filter in the manifest (tags are not delivered when the app is closed)
File imports	file_picker (SAF)	.vcf / .csv / .zip chosen by the user
Gallery photos	image_picker	Card photos
QR codes on cards	ML Kit barcode	Links shown with domain + warnings, opened only on tap
Deep links	**disabled** (`flutter_deeplinking_enabled=false`)	

Outbound hosts

Host	When	Data sent
api.github.com	Update check (Settings, or at launch when the user turned it on)	Standard HTTP request, no identifiers
github.com / objects.githubusercontent.com	Update download (user confirms)	none

Host	When	Data sent
Any URL / tel: / mailto: / geo:	Only when the user taps it	Opened in the user's own apps via url_launcher

Store policies were checked during the audit (domain 23); the date and sources are recorded in Appendix C.

Appendix B: Inventories (permissions, data, data flow, Data Safety draft)

CardKeep 0.6.0 (2010), commit cdcf49d, Android. Sources: `audit/artifact/manifest-xmltree.txt` (merged release manifest), `build/app/outputs/logs/manifest-merger-release-report.txt`, `lib/`.

Permissions

Permission	Source	Used? where
CAMERA	app manifest:2 (also camerax)	Scan screen live camera (`scan_screen.dart:14` `160`)
NFC	app manifest:4 (feature required=false)	Tap screen reader mode (`/tap`)
INTERNET	app manifest:7	Update check/download (`core/update/updater.dart`); also enables ML telemetry
REQUEST_INSTALL_PACKAGES	app manifest:9	In-app APK update (`updater.dart:201`)
POST_NOTIFICATIONS	app manifest:11	Follow-up reminders (`followups/reminders.dart:44-62`)
RECEIVE_BOOT_COMPLETED	app manifest:12 (+ flutter_local_notifications)	Re-schedule reminders (non-exported receiver)
VIBRATE	flutter_local_notifications	Notification vibration
ACCESS_NETWORK_STATE	androidx.media3-common (via camerax), datatransport (ML Kit)	Not by app code
RECORD_AUDIO	camera_android_camerax	No (`enableAudio: false`, `scan_screen.dart:146`)
READ_MEDIA_IMAGES	open_filex	No (gallery uses Photo Picker, `scan_screen.dart:294`)
READ_MEDIA_VIDEO	open_filex	No
READ_MEDIA_AUDIO	open_filex	No
READ_EXTERNAL_STORAGE (max 32)	open_filex	No
WRITE_EXTERNAL_STORAGE (max 28)	camera_android_camerax	No
com.axialforge.cardkeep.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION	androidx.core	Internal signature permission

Data inventory

Data class	Collected from	Stored	Encrypted	Sent off device
Name, title, company	OCR of card, QR/vCard, NFC, CSV/vCard import, manual	`app_flutter/card_organizer.sqlite` (people, roles, companies) + FTS index	No (MOB-SEC-0005)	Only in user-started share/export/backup; Android backup (MOB-AND-0001)
Phone, email, address, website	same	contact_points	No	same
Card photos (original q90, rectified q85, thumb)	Camera, gallery	`app_flutter/cards/{original,rectified,thumb}/<sha256>.jpg`	No	Backups (zip includes cards/), backup; auto-backup
EXIF / GPS of photos	Camera/gallery file	Stripped: re-encoded by OpenCV (`card_detector.dart:168-174`); picker asked without metadata	-	No
Logos cut from cards	Card image	`cards/logo/<sha256>.jpg`	No	Backups
OCR JSON	ML Kit on device	cards.ocr_json	No	Backups
Notes, tags, events, follow-up dates, career history	User	SQLite	No	Export/backup
My card (own details)	User	SQLite	No	User shares it (QR / vCard / Sh `my_card_screen.dart:11`
Pending captures	Camera	`cards/pending/`	No	No (excluded from backups `backup.dart:47`)
Temp OCR/region JPEGs, VACUUM temp	App	system temp	No	No
Automatic backups	App, weekly	`app_flutter/backups/*.zip`	No	Auto-backup only
Manual backups / exports (.zip, .vcf, .csv)	User action	User-chosen SAF location or share target	No	Wherever the user sends them
before_restore fallback	Restore	`app_flutter/before_restore/` (db + cards)	No	Auto-backup
Downloaded update APK	GitHub	cache `cardkeep-update.apk`	-	-
Settings (update-on-start etc.)	User	shared prefs	No	Auto-backup
SDK diagnostics (ML Kit)	ML Kit	-	TLS	Google (suspected, MOB-PRV

Data flow

`Camera / gallery (Photo Picker) / NFC / QR / .vcf / .csv / .zip -> on-device processing (OpenCV EXIF strip, ML Kit OCR + barcode, parsers) -> SQLite + cards/ in app-private storage -> weekly backups/ (keep 4) -> user action only: share sheet (vCard, My card, backup) / SAF save (export, backup) -> destination chosen by user -> tel:/mailto:/geo:/https links -> user's own apps (on tap) OS: Android Backup (allowBackup default) -> user's Google Drive / device transfer [undisclosed] Network: Settings > Updates (or opt-in at launch) -> api.github.com -> github.com / objects.githubusercontent.com (APK) ML Kit datatransport -> Google logging endpoint (usage/perf stats) [undisclosed, to confirm] Notifications: reminder text (name, company, event) on the lock screen [MOB-SEC-0002]`

Google Play Data Safety draft

Prerequisite: Play build drops REQUEST_INSTALL_PACKAGES and the self-updater (MOB-STORE-0001); privacy policy published (MOB-STORE-0004).

Question	Draft answer	Justification
Does the app collect or share any required user data types?	**Yes, collected** if ML Kit telemetry is confirmed (App info and performance > Diagnostics); otherwise **No**	Contact data, photos and notes never leave the device to the developer or a third party; "collected" means transmitted off the device. User-initiated sharing to a destination the user picks is not "sharing" under Play rules. Android Backup is exempt. ML Kit sends SDK usage/performance data to Google (follow Google's ML Kit Data Safety guidance; confirm with capture, MOB-PRV-0001).
Data types: Personal info (name, email, phone, address), Photos, Contacts, Other user-generated content	**Not collected** (processed on device only)	`lib/` has no network path for these; update check sends no identifiers.
App activity / App info and performance	**Diagnostics: collected by ML Kit (Google)**, not shared, not used for tracking, purpose: analytics/app functionality, cannot be turned off	Pending MOB-PRV-0001; remove the row if the transport is excluded.
Device or other IDs	Per ML Kit guidance (likely No)	Verify against Google's ML Kit disclosure.
Is all collected data encrypted in transit?	**Yes**	HTTPS (GitHub API; Google transport TLS).
Can users request that data be deleted?	**Yes** only after MOB-PRV-0002 is fixed (in-app delete actually purges); data is on-device, uninstall removes it	Today a contact delete is only a tombstone.
Data shared with third parties	**None**	No SDKs share data; ML Kit is a service provider processing on the developer's behalf.
Independent security review	No	
Families / ads	Not designed for children; no ads	

Appendix B: Software bill of materials (CardKeep 0.6.0)

Source: pubspec.lock at cdcf49d (dev dependencies excluded), licences read from the local pub cache LICENSE files, native libs from audit/artifact/native-libs.txt. Generated 2026-10-21. Outdated status from `flutter pub outdated` 2026-10-21. No pub.dev security advisory was reported by pub tooling; an external OSV/GHSA lookup was not performed (MANUAL REVIEW in G1).

Native and platform components in the APK

Component	Version	Origin	Licence	Notes
Flutter engine (libflutter.so)	3.47.0	Flutter SDK	BSD-3-Clause	Pinned in CI
Dart AOT app (libapp.so)	0.6.0	this repo	project licence	-
OpenCV (libdartcv.so)	via opencv_dart 2.2.2	opencv_dart	Apache-2.0	Image parsing of untrusted photos
SQLite (libsqlite3.so)	via sqlite3 3.5.2	sqlite3 build hook	Public domain	FTS5 used
ML Kit OCR (libmlkit_google_ocr_pipeline.so)	via google_mlkit_text_recognition 0.17.1	Google	ML Kit Terms	Bundled model, offline
ML Kit barcode (libbarhopper_v3.so)	via google_mlkit_barcode_scanning 0.16.1	Google	ML Kit Terms	Bundled model
CameraX JNI (libimage_processing_util_jni.so, libsurface_util_jni.so)	via camera_android_camerax 0.7.5+1	AndroidX	Apache-2.0	-
libdartjni.so	jni 1.1.0	Dart team	BSD-3-Clause	-
desugar_jdk_libs	2.1.4	Google	GPL-2.0 with Classpath Exception	Core library desugaring

Dart / Flutter packages

Name	Version	Direct/transitive	Licence	Notes on risk
archive	4.5.2	direct	MIT	Parses user-chosen .zip backups (zip-slip handling assessed in the security domain)
camera	0.12.1	direct	BSD-3-Clause	Pulls RECORD_AUDIO into manifest (MOB-BLD-0001)
crypto	3.0.7	direct	BSD-3-Clause	SHA-256 for update and image hashing
device_info_plus	13.3.0	direct	BSD-3-Clause	-
drift	2.35.2	direct	MIT	-
drift_flutter	0.3.1	direct	MIT	-
file_picker	13.1.0	direct	MIT	SAF imports
flutter	0.0.0	direct	BSD-3-Clause (Flutter SDK)	-
flutter_local_notifications	22.3.2	direct	BSD-3-Clause	Boot receiver (exported=false)
flutter_riverpod	3.4.3	direct	MIT	-
go_router	18.1.0	direct	BSD-3-Clause	18.1.1 available
google_mlkit_barcode_scanning	0.16.1	direct	MIT	Bundles ML Kit barcode (libbarhopper_v3.so); ML Kit terms
google_mlkit_text_recognition	0.17.1	direct	MIT	Bundles Google ML Kit OCR (proprietary ML Kit terms), on-device
http	1.6.0	direct	BSD-3-Clause	Only used by updater to GitHub
image	4.12.0	direct	MIT	Decodes untrusted images in Dart
image_picker	1.2.4	direct	Apache-2.0	-
intl	0.20.3	direct	BSD-3-Clause	-
ndef_record	1.4.2	direct	MIT	1.5.0 exists, not resolvable with nfc_manager_ndef
nfc_manager	4.2.1	direct	MIT	Reads untrusted NDEF tags
nfc_manager_ndef	1.1.0	direct	MIT	-
open_filex	5.0.0	direct	BSD-3-Clause	-
opencv_dart	2.2.2	direct	Apache-2.0	Bundles native OpenCV (libdartcv.so 10.9 MB); parses untrusted images
package_info_plus	10.2.2	direct	BSD-3-Clause	-
path	1.9.1	direct	BSD-3-Clause	-
path_provider	2.1.6	direct	BSD-3-Clause	-
permission_handler	13.0.2	direct	MIT	-
phone_numbers_parser	9.0.28	direct	MIT	-
qr_flutter	4.1.0	direct	BSD-3-Clause	-
screen_brightness	2.1.11	direct	MIT	-
share_plus	13.3.1	direct	BSD-3-Clause	-
timezone	0.11.2	direct	BSD-2-Clause	-
url_launcher	6.3.3	direct	BSD-3-Clause	Opens links only on tap
uuid	4.6.0	direct	MIT	-
_fe_analyzer_shared	109.0.0	transitive	BSD-3-Clause	-
analyzer	14.5.0	transitive	BSD-3-Clause	-
android_file_picker	2.1.1	transitive	MIT	-
args	2.7.0	transitive	BSD-3-Clause	-
async	2.13.1	transitive	BSD-3-Clause	-

Name	Version	Direct/transitive	Licence	Notes on risk
boolean_selector	2.1.2	transitive	BSD-3-Clause	-
build	4.0.11	transitive	BSD-3-Clause	-
build_config	1.3.3	transitive	BSD-3-Clause	-
build_daemon	4.1.7	transitive	BSD-3-Clause	-
built_collection	5.1.2	transitive	BSD-3-Clause	-
built_value	8.13.0	transitive	BSD-3-Clause	-
camera_android_camerax	0.7.5+1	transitive	BSD-3-Clause	-
camera_avfoundation	0.10.3+1	transitive	BSD-3-Clause	-
camera_platform_interface	2.15.0	transitive	BSD-3-Clause	-
camera_web	0.3.5+6	transitive	BSD-3-Clause	-
change_case	2.2.0	transitive	MIT	-
characters	1.4.1	transitive	BSD-3-Clause	-
charcode	1.4.0	transitive	BSD-3-Clause	-
checked_yaml	2.0.4	transitive	BSD-3-Clause	-
cli_util	0.6.0	transitive	BSD-3-Clause	-
clock	1.1.3	transitive	Apache-2.0	-
code_assets	1.2.1	transitive	BSD-3-Clause	-
collection	1.19.1	transitive	BSD-3-Clause	-
convert	3.1.2	transitive	BSD-3-Clause	-
cross_file	0.3.5+5	transitive	BSD-3-Clause	-
cupertino_ui	1.1.3	transitive	BSD-3-Clause	-
dart_style	3.1.14	transitive	BSD-3-Clause	-
dartcv4	2.2.2	transitive	Apache-2.0	OpenCV bindings; 2.3.1 available
dbus	0.8.0	transitive	MPL-2.0	MPL-2.0, Linux-only, not in APK
device_info_plus_platform_interface	8.1.0	transitive	BSD-3-Clause	-
fake_async	1.3.3	transitive	Apache-2.0	-
ffi	2.2.0	transitive	BSD-3-Clause	-
ffi_leak_tracker	0.1.2	transitive	BSD-3-Clause	-
file	7.0.1	transitive	BSD-3-Clause	-
file_picker_darwin	2.3.2	transitive	MIT	-
file_picker_linux	2.0.2	transitive	MIT	-
file_picker_platform_interface	4.2.0	transitive	MIT	-
file_picker_web	4.2.0	transitive	MIT	-
file_selector_linux	0.9.4+1	transitive	BSD-3-Clause	-
file_selector_macos	0.9.5+2	transitive	BSD-3-Clause	-
file_selector_platform_interface	2.7.0	transitive	BSD-3-Clause	-
file_selector_windows	0.9.3+6	transitive	BSD-3-Clause	-
fixnum	1.1.1	transitive	BSD-3-Clause	-
flutter_local_notifications_linux	8.0.2	transitive	BSD-3-Clause	-
flutter_local_notifications_platform_interface	12.2.0	transitive	BSD-3-Clause	-
flutter_local_notifications_web	1.0.0	transitive	BSD-3-Clause	-
flutter_local_notifications_windows	3.1.1	transitive	BSD-3-Clause	-
flutter_localizations	0.0.0	transitive	BSD-3-Clause (Flutter SDK)	-
flutter_plugin_android_lifecycle	2.0.35	transitive	BSD-3-Clause	-
flutter_web_plugins	0.0.0	transitive	BSD-3-Clause (Flutter SDK)	-
glob	2.2.0	transitive	BSD-3-Clause	-
google_mlkit_commons	0.13.0	transitive	MIT	-
graphs	2.3.2	transitive	BSD-3-Clause	-
hooks	2.0.2	transitive	BSD-3-Clause	-
http_multi_server	3.2.2	transitive	BSD-3-Clause	-
http_parser	4.1.2	transitive	BSD-3-Clause	-
image_picker_android	0.8.13+25	transitive	Apache-2.0	-
image_picker_for_web	3.1.1	transitive	BSD-3-Clause	-
image_picker_ios	0.8.13+12	transitive	Apache-2.0	-
image_picker_linux	0.2.2	transitive	BSD-3-Clause	-
image_picker_macos	0.2.2+1	transitive	BSD-3-Clause	-
image_picker_platform_interface	2.11.2	transitive	BSD-3-Clause	-
image_picker_windows	0.2.2	transitive	BSD-3-Clause	-
io	1.1.0	transitive	BSD-3-Clause	-
jni	1.1.0	transitive	BSD-3-Clause	-
jni_flutter	1.0.4+1	transitive	BSD-3-Clause	-
jni_util	1.0.0	transitive	BSD-3-Clause	-
json_annotation	4.12.0	transitive	BSD-3-Clause	-
leak_tracker	11.0.2	transitive	BSD-3-Clause	-
leak_tracker_flutter_testing	3.0.10	transitive	BSD-3-Clause	-
leak_tracker_testing	3.0.2	transitive	BSD-3-Clause	-

Name	Version	Direct/transitive	Licence	Notes on risk
lints	6.1.0	transitive	BSD-3-Clause	-
listen	1.0.1	transitive	BSD-3-Clause	-
logging	1.3.0	transitive	BSD-3-Clause	-
matcher	0.12.20	transitive	BSD-3-Clause	-
material_color_utilities	0.13.0	transitive	Apache-2.0	-
material_ui	1.7.0	transitive	BSD-3-Clause	-
meta	1.18.3	transitive	BSD-3-Clause	-
mime	2.1.0	transitive	BSD-3-Clause	-
native_toolchain_c	0.19.2	transitive	BSD-3-Clause	-
native_toolchain_cmake	0.3.2	transitive	Apache-2.0	-
objective_c	9.5.0	transitive	BSD-3-Clause	-
package_config	3.0.0	transitive	BSD-3-Clause	-
package_info_plus_platform_interface	4.1.0	transitive	BSD-3-Clause	-
path_provider_android	2.3.1	transitive	BSD-3-Clause	-
path_provider_foundation	2.6.0	transitive	BSD-3-Clause	-
path_provider_linux	2.2.2	transitive	BSD-3-Clause	-
path_provider_platform_interface	2.1.3	transitive	BSD-3-Clause	-
path_provider_windows	2.3.0	transitive	BSD-3-Clause	-
permission_handler_android	14.1.0	transitive	MIT	-
permission_handler_apple	9.6.2	transitive	MIT	-
permission_handler_html	0.1.4+1	transitive	MIT	-
permission_handler_platform_interface	4.4.1	transitive	MIT	-
permission_handler_windows	0.2.2	transitive	MIT	-
petitparser	7.0.2	transitive	MIT	-
platform	3.2.0	transitive	BSD-3-Clause	-
plugin_platform_interface	2.1.8	transitive	BSD-3-Clause	-
pool	1.5.3	transitive	BSD-3-Clause	-
posix	6.5.2	transitive	MIT	-
pub_semver	2.2.1	transitive	BSD-3-Clause	-
pubspec_parse	1.6.0	transitive	BSD-3-Clause	-
qr	3.0.2	transitive	BSD-3-Clause	-
recase	4.1.0	transitive	BSD-2-Clause	-
record_use	0.6.0	transitive	BSD-3-Clause	-
riverpod	3.4.3	transitive	MIT	-
screen_brightness_android	2.1.6	transitive	MIT	-
screen_brightness_ios	2.1.4	transitive	MIT	-
screen_brightness_macos	2.1.4	transitive	MIT	-
screen_brightness_ohos	2.1.4	transitive	MIT	-
screen_brightness_platform_interface	2.1.2	transitive	MIT	-
screen_brightness_windows	2.1.2	transitive	MIT	-
share_plus_platform_interface	7.2.0	transitive	BSD-3-Clause	-
shelf	1.4.3	transitive	BSD-3-Clause	-
shelf_web_socket	3.0.0	transitive	BSD-3-Clause	-
sky_engine	0.0.0	transitive	BSD-3-Clause (Flutter SDK)	-
source_gen	4.3.1	transitive	BSD-3-Clause	-
source_span	1.10.2	transitive	BSD-3-Clause	-
sqlcipher_flutter_libs	0.7.0+eol	transitive	Apache-2.0	EOL stub package; SQLCipher not used
sqlite3	3.5.2	transitive	MIT	Native SQLite via build hooks (libsqlite3.so); 3.7.1 available
sqlite3_flutter_libs	0.6.0+eol	transitive	MIT	EOL stub package
sqlparser	0.45.0	transitive	MIT	-
stack_trace	1.12.2	transitive	BSD-3-Clause	-
state_notifier	1.0.0	transitive	MIT	-
stream_channel	2.1.4	transitive	BSD-3-Clause	-
stream_transform	2.1.2	transitive	BSD-3-Clause	-
string_scanner	1.4.1	transitive	BSD-3-Clause	-
term_glyph	1.2.2	transitive	BSD-3-Clause	-
test_api	0.7.12	transitive	BSD-3-Clause	-
typed_data	1.4.0	transitive	BSD-3-Clause	-
url_launcher_android	6.3.33	transitive	BSD-3-Clause	-
url_launcher_ios	6.4.2	transitive	BSD-3-Clause	-
url_launcher_linux	3.2.3	transitive	BSD-3-Clause	-
url_launcher_macos	3.2.6	transitive	BSD-3-Clause	-
url_launcher_platform_interface	2.3.2	transitive	BSD-3-Clause	-
url_launcher_web	2.4.3	transitive	BSD-3-Clause	-
url_launcher_windows	3.1.6	transitive	BSD-3-Clause	-
vector_math	2.4.0	transitive	BSD-3-Clause	-

Name	Version	Direct/transitive	Licence	Notes on risk
vm_service	15.4.0	transitive	BSD-3-Clause	-
watcher	1.2.1	transitive	BSD-3-Clause	-
web	1.1.1	transitive	BSD-3-Clause	-
web_socket	1.0.1	transitive	BSD-3-Clause	-
web_socket_channel	3.0.3	transitive	BSD-3-Clause	-
win32	6.4.0	transitive	BSD-3-Clause	-
win32_registry	3.0.3	transitive	BSD-3-Clause	-
windows_file_picker	2.0.1	transitive	MIT	-
xdg_directories	1.1.0	transitive	BSD-3-Clause	-
xml	7.0.1	transitive	MIT	-
yaml	3.1.4	transitive	MIT	-
yaml_edit	2.2.4	transitive	BSD-3-Clause	-

Build-only transitive packages (analyzer, build*, source_gen, dart_style, native_toolchain_*, hooks, code_assets) run at build time and do not ship in the APK. Platform-specific implementations for iOS, macOS, Windows, Linux and web are resolved but not compiled into the Android APK.

Appendix C: Store, device and open items

Policies checked (date + sources)

All fetched 2026-10-21.

Policy	Current requirement	Source
Target API level	New apps and updates must target API 36 by 2026-08-31	https://support.google.com/googleplay/android-developer/answer/11926878
REQUEST_INSTALL_PACKAGES	Only for apps whose core function is package transfer; self-updating outside Play not permitted	https://support.google.com/googleplay/android-developer/answer/12085295
Device and Network Abuse	No updating by means other than Play	https://support.google.com/googleplay/android-developer/answer/9888379
Photo and Video Permissions	READ_MEDIA_IMAGES/VIDEO only for broad-access core use, with declaration; otherwise remove and use Photo Picker; mandatory since 2025-05-28	https://support.google.com/googleplay/android-developer/answer/14115180
16 KB page size	Apps targeting 35+ with native code must support 16 KB on 64-bit; updates blocked after 2027-02-01	https://developer.android.com/guide/practices/page-sizes
AAB + Play App Signing	Required for new apps	https://developer.android.com/guide/app-bundle
Privacy policy	Required in Console and in app	https://support.google.com/googleplay/android-developer/answer/10144311
Data safety	Required for all apps	https://support.google.com/googleplay/android-developer/answer/10787469
Metadata	Listing must be accurate	https://support.google.com/googleplay/android-developer/answer/9898842

Play submission checklist

Item	Status	Action
targetSdk 36	Done	-
16 KB alignment (zip + ELF)	Done	Recheck after dependency upgrades
AAB + Play App Signing	Missing	MOB-STORE-0003
Play flavour without updater / REQUEST_INSTALL_PACKAGES	Missing	MOB-STORE-0001 (S17.9)
Remove RECORD_AUDIO, READ_MEDIA_*	Missing	MOB-STORE-0002
Privacy policy + in-app link	Missing	MOB-STORE-0004 (S17.6, S15.11)
Data safety form	Not started	MOB-STORE-0005
Package name decision recorded	Open	MOB-STORE-0007
Content rating questionnaire	Not started	Fill in Console (expected Everyone)
Target audience	Not started	Declare adults; not a Families app
Store listing text and screenshots	Not started	Write from updated README (MOB-STORE-0006)
Closed test (12 testers, 14 days for new personal accounts)	Not started	ROADMAP D7; verify current tester rule at submission
Account deletion	N/A	No accounts

GitHub distribution: fine as is (updater is user-started, signed with the same key).

Listing accuracy

Claim	Where	True?
No account, no cloud, keep everything local	Repo description, README, Settings	Yes
Cards read on the phone, nothing uploaded	README	Yes (bundled ML Kit models)
Only goes online for update checks; startup check off by default	README Privacy	Yes per Appendix A
"What it does (0.2.0)"	README	No, app is 0.6.0 (MOB-STORE-0006)
Light, Medium and Dark themes	README	No, Medium removed in 0.6.0
NFC, import/export, tags, events, career tracking are "next"	README	No, shipped
Topics ml-kit, ocr, opencv, offline-first, privacy	GitHub topics	Yes

Device matrix

Store-related device checks needed: Play build on a 16 KB page-size emulator image (Android 15+ 16 KB system image) to confirm the app launches and scans; Photo Picker import on API 33+ and API 29 after MOB-STORE-0002.

Manual review queue

- Confirm ML Kit bundled text/barcode models send no telemetry (affects Data safety).
- Decide signing key strategy for Play App Signing (shared with GitHub key or not).
- Confirm at runtime whether any READ_MEDIA_* or RECORD_AUDIO prompt ever appears (MOB-STORE-0002 confidence medium).
- Content rating questionnaire and target audience answers.

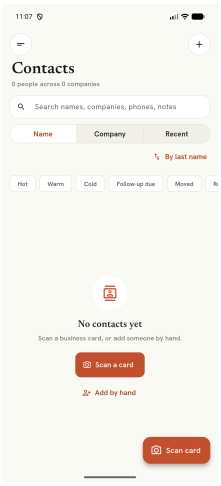
Appendix D: Runtime evidence (GUI, UX, accessibility, compatibility, performance)

Device: emulator-5554, Pixel_10_Pro_XL_test, Android 16 x86_64 image (`getprop ro.build.version.sdk` = 37), 1344x2992, 480 dpi (3.0x). Build: shipped `audit/artifact/CardKeep-0.6.0-x86_64.apk`, installed after uninstalling any previous `com.axialforge.cardkeep`. Data: 2 contacts imported from `/sdcard/Download/test_import.vcf`, 1 added by hand with long fields. Font scale and night mode were reset to 1.0 / off at the end.

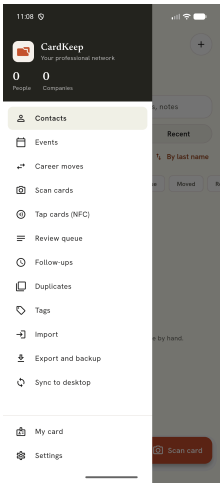
Measurements

Metric	Value	How measured
Cold start, run 1 (first after install)	1621 ms TotalTime	`am force-stop` then `am start -W -n com.axialforge.cardkeep/.MainActivity`
Cold start, run 2	886 ms	same
Cold start, run 3	742 ms	same
APK arm64-v8a	53.4 MB (55,989,997 B)	`audit/artifact` file size
APK armeabi-v7a	41.7 MB (43,700,579 B)	same
APK x86_64	59.6 MB (62,510,818 B)	same
Memory idle (Contacts)	86.9 MB PSS, 212.5 MB RSS, native heap 25.8 MB	`dumpsys meminfo`
Memory, Scan open (camera live)	182.7 MB PSS, 313.3 MB RSS, native heap 99.2 MB	same
Memory after leaving Scan	167.5 MB PSS (165.8 MB after 11 more screens)	same (MOB-PERF-0001)
Frames / jank	Not measurable: gfxinfo counted 4 frames only (Flutter surface)	`dumpsys gfxinfo ... reset`, scroll, read
Orientation	Not locked; landscape renders and scrolls	`user_rotation 1`
Font scale 1.3 / 2.0	No clipping; long text wraps or ellipsizes	`settings put system font_scale`
Dark theme	Renders correctly	`cmd uimode night yes`
Touch targets < 48 dp	DiscButton 46 dp (MOB-A11Y-0001); scan mode 34 dp tall (MOB-A11Y-0002)	`uiautomator dump` bounds / 3.0
Unlabelled icon buttons	none found	`uiautomator dump`, all screens
Back stack	8 Back presses after visiting 9 drawer sections (MOB-UX-0001)	`input keyevent BACK` + `dumpsys window`

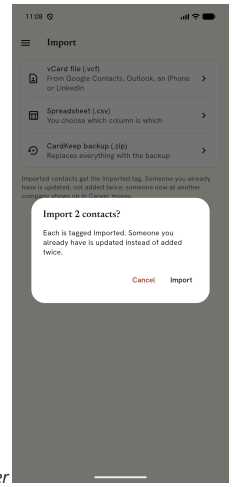
Key screenshots



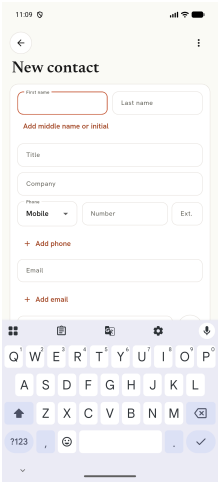
Empty Contacts with empty state



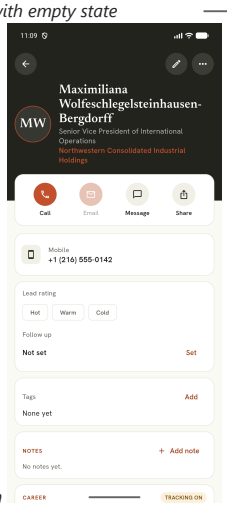
Navigation drawer



vCard import confirmation



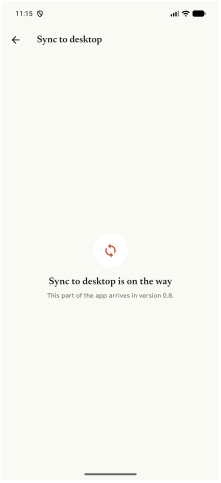
New contact form



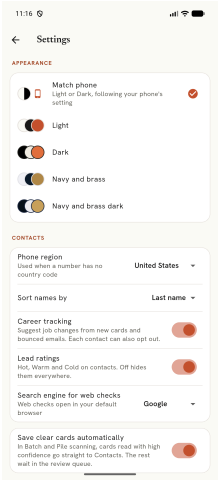
Contact detail with long name/title/company



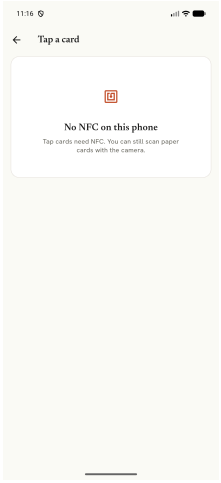
Scan screen (emulator



camera scene)

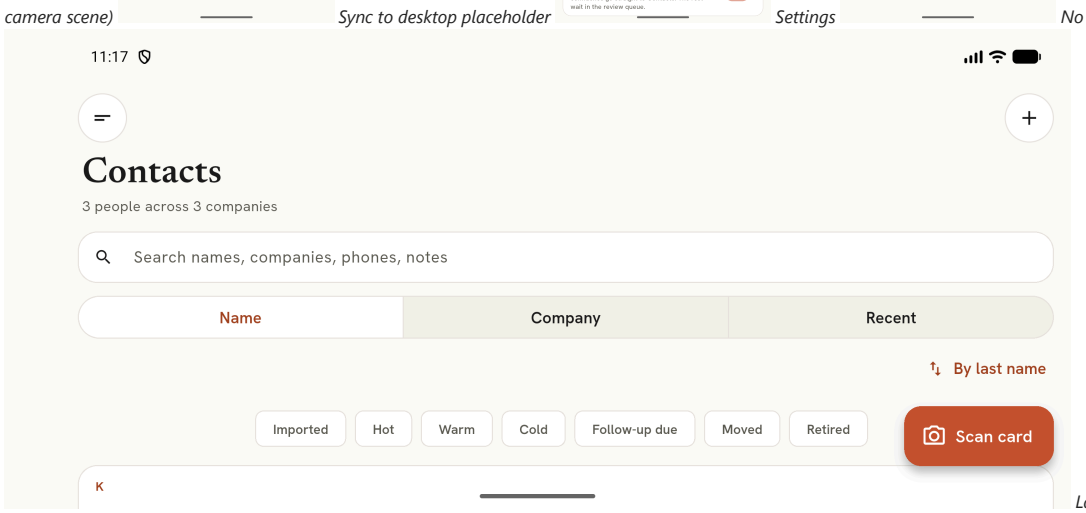


Sync to desktop placeholder

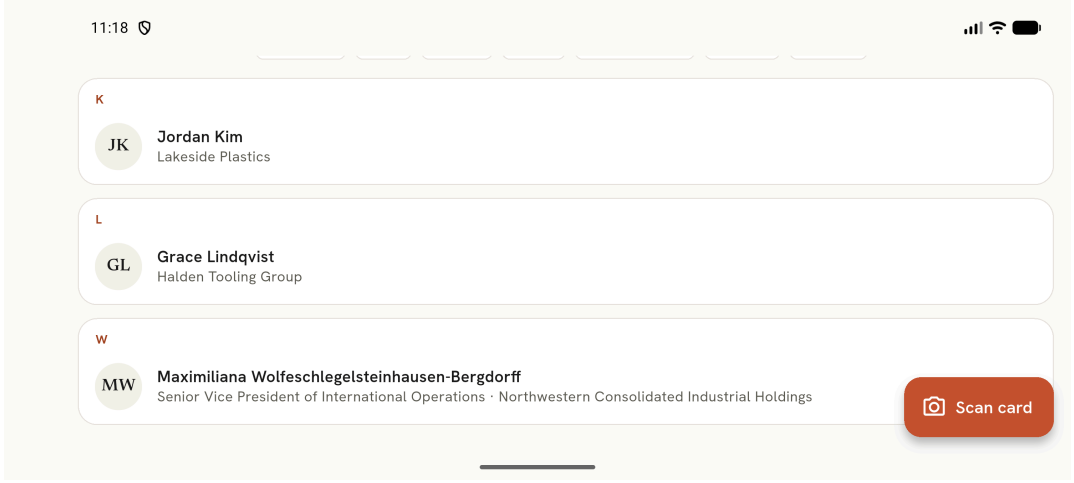


Settings

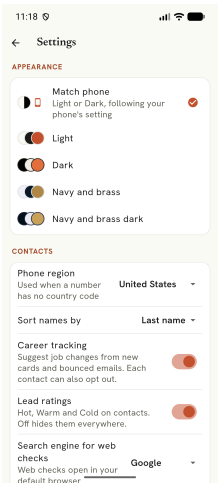
No NFC state



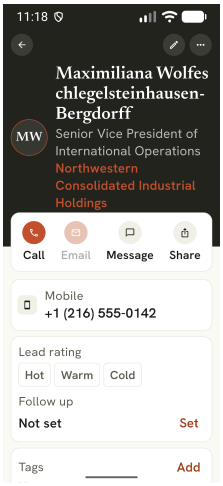
Landscape Contacts



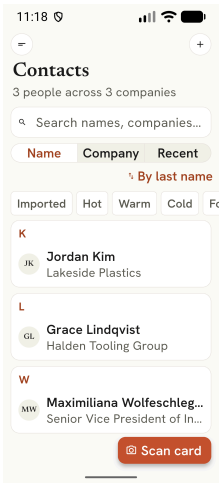
Landscape scrolled



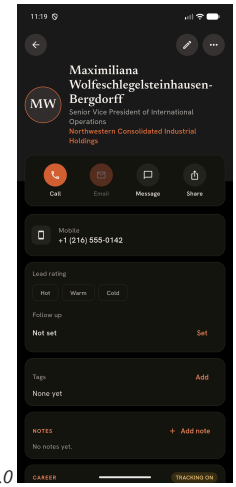
Settings at font 1.3



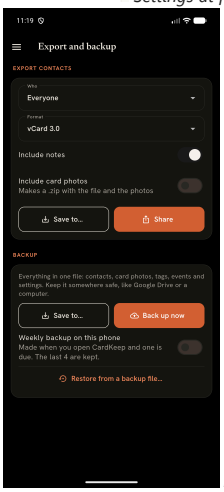
Detail at font 2.0



Contacts at font 2.0



Dark detail



Dark Export and backup

Not covered (BLOCKED)

Real device (Galaxy S25 Ultra) behaviour, NFC, real-camera OCR quality, API 24-35 devices, frame timing (needs a profile build + DevTools), and large-library scroll performance (release build cannot be seeded).

Findings index

ID	Sev	Status
MOB-REL-0001	S4	open
MOB-PRV-0001	S3	open
MOB-PRV-0002	S3	open
MOB-REL-0002	S3	open
MOB-STORE-0001	S3	open
MOB-STORE-0002	S3	open
MOB-REL-0003	S2	open
MOB-REL-0004	S2	open
MOB-SEC-0001	S2	open
MOB-SEC-0100	S2	open
MOB-STORE-0003	S2	open
MOB-STORE-0004	S2	open
MOB-UX-0001	S2	open
MOB-A11Y-0001	S1	open
MOB-A11Y-0002	S1	open
MOB-API-0001	S1	open
MOB-BLD-0002	S1	open
MOB-BLD-0003	S1	open
MOB-BLD-0004	S1	open
MOB-PRV-0003	S1	open
MOB-PRV-0004	S1	open
MOB-REL-0005	S1	open
MOB-REL-0006	S1	open
MOB-REL-0007	S1	open
MOB-REL-0008	S1	open
MOB-REL-0009	S1	open
MOB-SEC-0002	S1	open
MOB-SEC-0003	S1	open
MOB-SEC-0006	S1	open
MOB-SEC-0101	S1	open
MOB-SEC-0102	S1	open
MOB-SEC-0103	S1	open
MOB-STORE-0005	S1	open
MOB-STORE-0006	S1	open
MOB-STORE-0007	S1	open
MOB-UX-0002	S1	open
MOB-BLD-0005	S0	open
MOB-PERF-0001	S0	open
MOB-SEC-0004	S0	open
MOB-SEC-0005	S0	open
MOB-SEC-0007	S0	open
MOB-AND-0001	S2	duplicate (tracked as MOB-SEC-0001)
MOB-BLD-0001	S2	duplicate (tracked as MOB-STORE-0002)